

Understanding Cybersecurity Management System

(UNECE R155, ISO/SAE 21434)

Cyber Security Governance Unit

- Background of UNECE R155 enactment
- Understanding Cybersecurity Management System (CSMS) based on ISO/SAE 21434
 - Organizational Cybersecurity Management [Clause 5]
 - Project Dependent Cybersecurity Management [Clause 6]
 - Distributed Cybersecurity Activities [Clause 7]
 - Concept [Clause 9]
 - Product Development [Clause 10]
 - Cybersecurity Validation [Clause 11]
 - Production [Clause 12]
 - Operations and Maintenance [Clause 13]
 - End of Cybersecurity Support and Decommissioning [Clause 14]

Unintended turning-off of headlamp during night driving at medium speed??

Steering wheel is locked during driving??

Speed limit?? Brake system?? Car door??

Driving on the highway when suddenly.....

Air conditioning starts blasting at the maximum setting??

Radio switches to the local hip hop station and starts playing at full volume??

Windshield wipers turn on and wiper fluid blurs the glass??

Picture of the two hackers appear on the car's infotainment display??

Disclosure of the personal information without the customer's consent??



- Security risks that threaten autonomous and connected vehicles.

Attacks on Smart Remote Keys

Attacks on Cloud-Based Networks

Malware Attacks – Software Security

Sensors

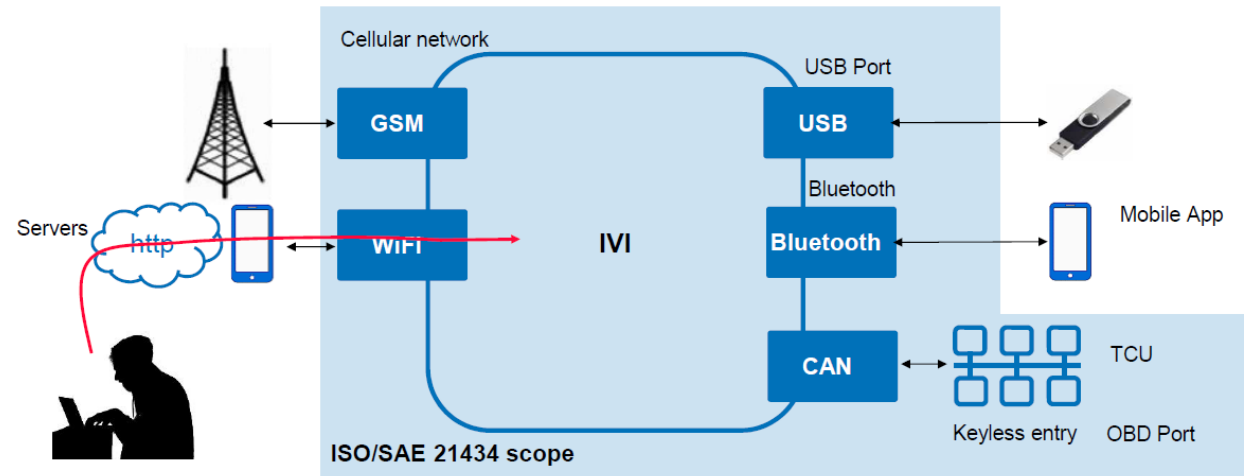
- GPS / LiDAR (Light Detection and Ranging) / IMU (Inertial Measurement Unit)

Network Attacks

- V2X Network Attack
- V2V Network Attack
- V2I Network Attack

APT (Advanced Persistent Threat) Attack

- Engine Control Unit
- OBD Port-based attack

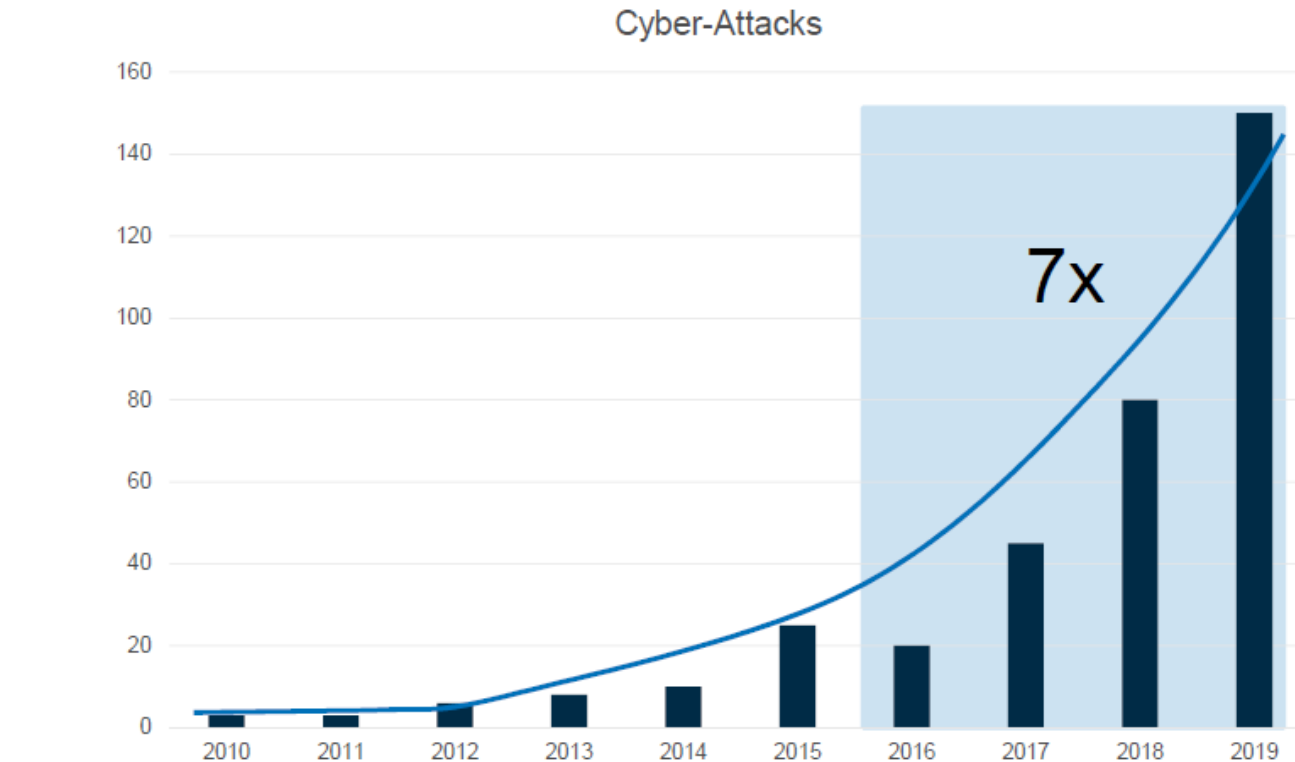


- Malicious code exploits can cause real physical harm to car passenger and users

Increase of Cybersecurity Attack

LGE Internal Use Only

The number of cyber-attacks on smart mobility has increased by 7x within 3 years



Source: Upstream Automotive Security Report 2020



2017

Tesla: LAS VEGAS — For the second time, Chinese security researchers were able to hack a Tesla Model X, **turning on the brakes remotely** and getting the **doors and trunk to open** and close while blinking the lights in time to music streamed from the car's radio — an effect they dubbed "the unauthorized Xmas show."

2018 **Forbes**

All Brands: Just when the OEMs felt they had released a secure vehicle, Calamp releases a **misconfigured server** in 2018 that provided open **access to more than 1.5 million IoT devices** provided by Viper SmartStart, thereby allowing unwanted **location of vehicles, password resets, door unlocks, alarm disables, engine starts and vehicle thefts**.

2020 **Edinburgh News**

Ford, VW: The consumer group "Which?" exposes security flaws that range from remotely exposing **private, customer information** (e.g. **location history, contact info**) to **disabling the traction control system**.

Enactment Background Of UNECE WP29 R155

- Enactment background of UNECE WP.29 R155
 - As electronic control devices increase in automobiles and connected to communication, cybersecurity vulnerabilities and threats such as illegal control of automobiles and infringement of privacy have been increased.
 - The damage to hacking, such as cyber attacks on automobiles, can lead to critical impact on road users that's why cybersecurity is essential.

UNECE WP.29 R155, the first international standard for automobile cybersecurity, was adopted based on international consensus on the importance of car cyber security on Jan 2021.



12th UN, Informal Working Group on Cybersecurity & OTA (2018, Seoul)

*In the European Union, the new regulation on cybersecurity (UNECE WP.29/R155) will be mandatory **for all new vehicle types from July 2022** and will become mandatory **for all vehicles produced from July 2024***

Organization Structure Of UNECE WP29

LG Internal Use Only

Organization structure



UN
*United Nations

UNECE
*United Nations Economic Commission For Europe

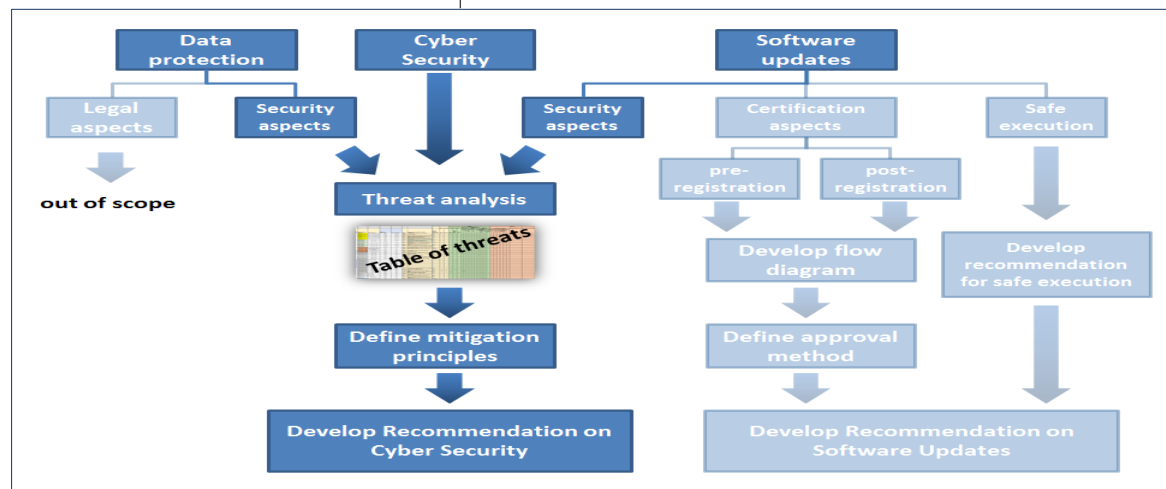
ITC
*Inland Transport Committee

WP 29
*World Forum For Harmonization Of Vehicle Regulations

GRVA
*Working Party on Automated/Autonomous and Connected Vehicles

- UNECE : One of the five regional commissions under the jurisdiction of the United Nations Economic and Social Council. (56 members states)

- WP29 : Unique worldwide regulatory forum within the institutional framework of the UNECE Inland Transport Committee.



CSMS

(Cybersecurity Management System)

UNECE WP.29 enacted the Cyber Security Management System (CSMS).

UN Regulation No. 155

Uniform provisions concerning the approval of vehicles with regards to cyber security and cyber security management system

Contents

	<i>Page</i>
1. Scope	4
2. Definitions.....	4
3. Application for approval	5
4. Markings	5
5. Approval	6
6. Certificate of Compliance for Cyber Security Management System	8
7. Specifications	9
8. Modification and extension of the vehicle type	12
9. Conformity of production	12
10. Penalties for non-conformity of production	12
11. Production definitively discontinued.....	12
12. Names and addresses of Technical Services responsible for conducting approval test, and of Type Approval Authorities	13

Annexes

1 Information document	14
2 Communication	16
3 Arrangement of approval mark	17
4 Model of Certificate of Compliance for CSMS.....	18
5 List of threats and corresponding mitigations	19

- Applicable to : Passenger cars, commercial vehicles, trailers with electronic control systems, and small vehicles with autonomous driving functions, related automobile manufacturers, etc.
- Key takeaways: **Manufacturers** must have a vehicle cybersecurity management system (CSMS) and conduct risk assessment and management for each vehicle type.
- Annex 5 : List of threats and corresponding mitigations
 - Part A. Vulnerability or attack method related to the threats
 - Part B. Mitigations to the threats intended for vehicles

- ISO/SAE 21434 supports to implement a CSMS as it is required by UNECE R155
- ISO/SAE 21434 only describes the tasks for a process, but leaves the design to the users

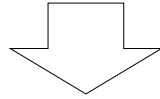
Regulation	UNECE WP29 R155 ■ Requires CSMS at high level - (7.2) Requirements for the Cyber Security Management System - (7.2.1) For the assessment the Approval Authority or its Technical Service shall verify that the vehicle manufacturer has a Cyber Security Management System in place and shall verify its compliance with this Regulation.
Standard	ISO/SAE 21434 ■ Provides guideline how to implement a CSMS - (Clause 5) Organizational cybersecurity management - (Clause 6) Project dependent cybersecurity management - (Clause 7) Distributed cybersecurity activities - (Clause 8) Continuous cybersecurity activities

OEM?? Tier1??

- In a secure system of the OEM, all components of the Tiers need to be secure

OEM

- UNECE R155 has to be applied for homologation from 2024-07-01 on
- OEMs need to obtain a valid Cyber Security Management System (CSMS), "Certificate of Compliance"
- ISO/SAE 21434 concretizes the requirements of UNECE R155 and is therefore used for an audit



Establish CSMS

- must obtain CSMS certification

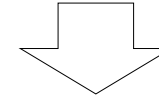
Apply cybersecurity to vehicle according to CSMS

- must obtain VTA

*VTA : Vehicle Type Approval

Tier

- Tiers are excluded from UNECE R155, but...
- OEMs can require a CSMS certificate
- ISO/SAE 21434 will be relevant for Tiers



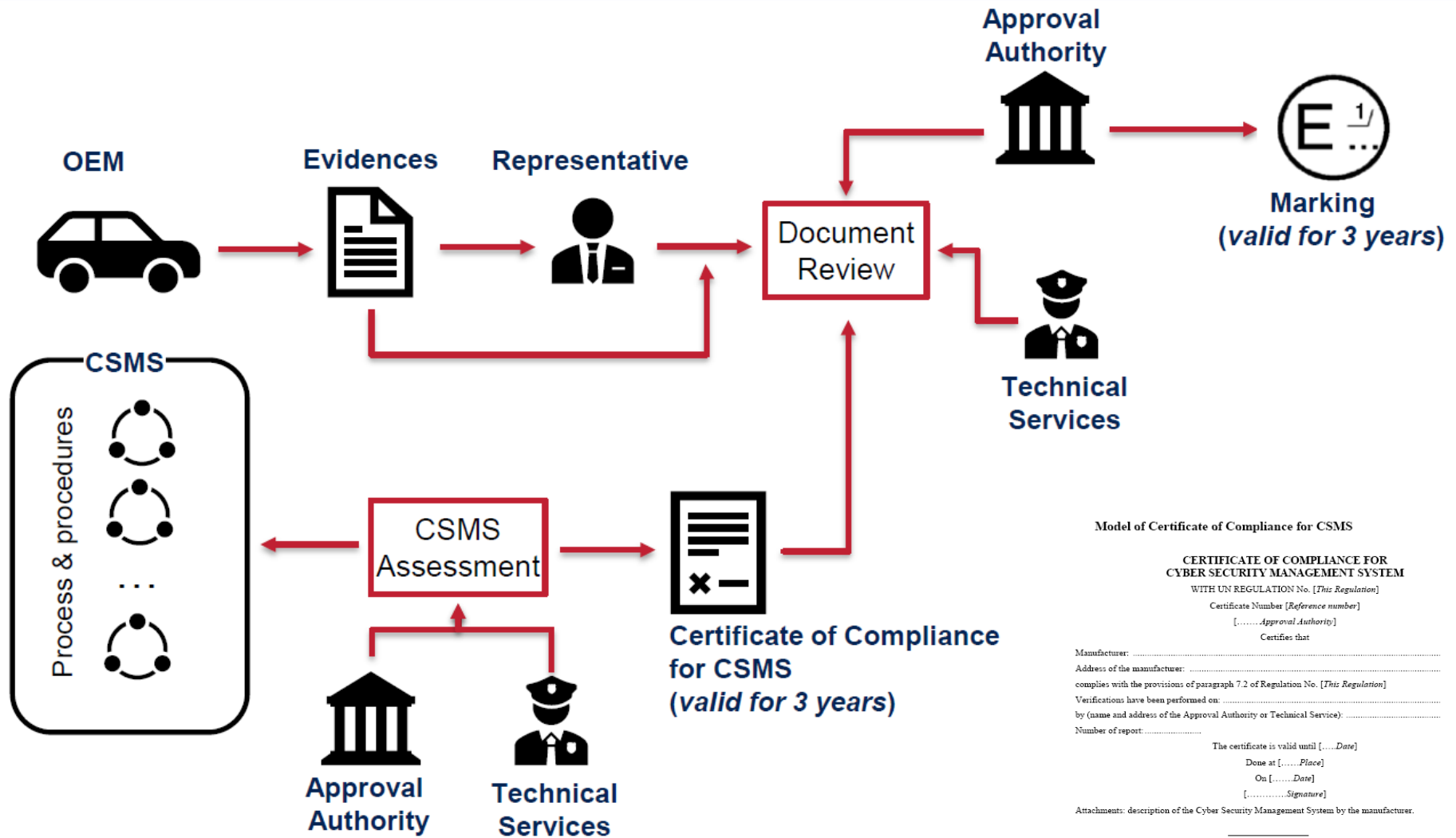
Establish CSMS

- (Optional) obtain CSMS certification

Apply cybersecurity to products according to CSMS

- provide supporting documentation to help OEMs obtain VTA

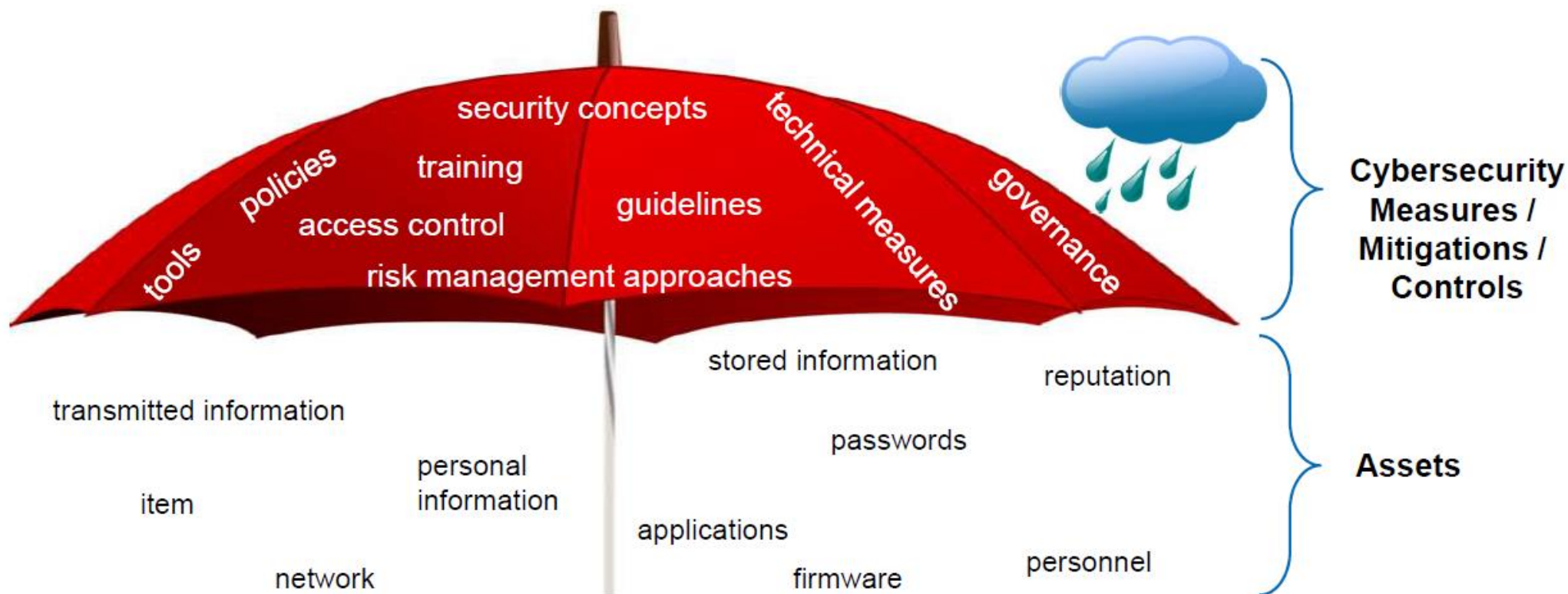
Tier shall ensure that product development is conducted to ensure cybersecurity compliance based on the ISO/SAE 21434 standard and shall submit and retain all deliverables required by the standard to enable OEMs to obtain a VTA.



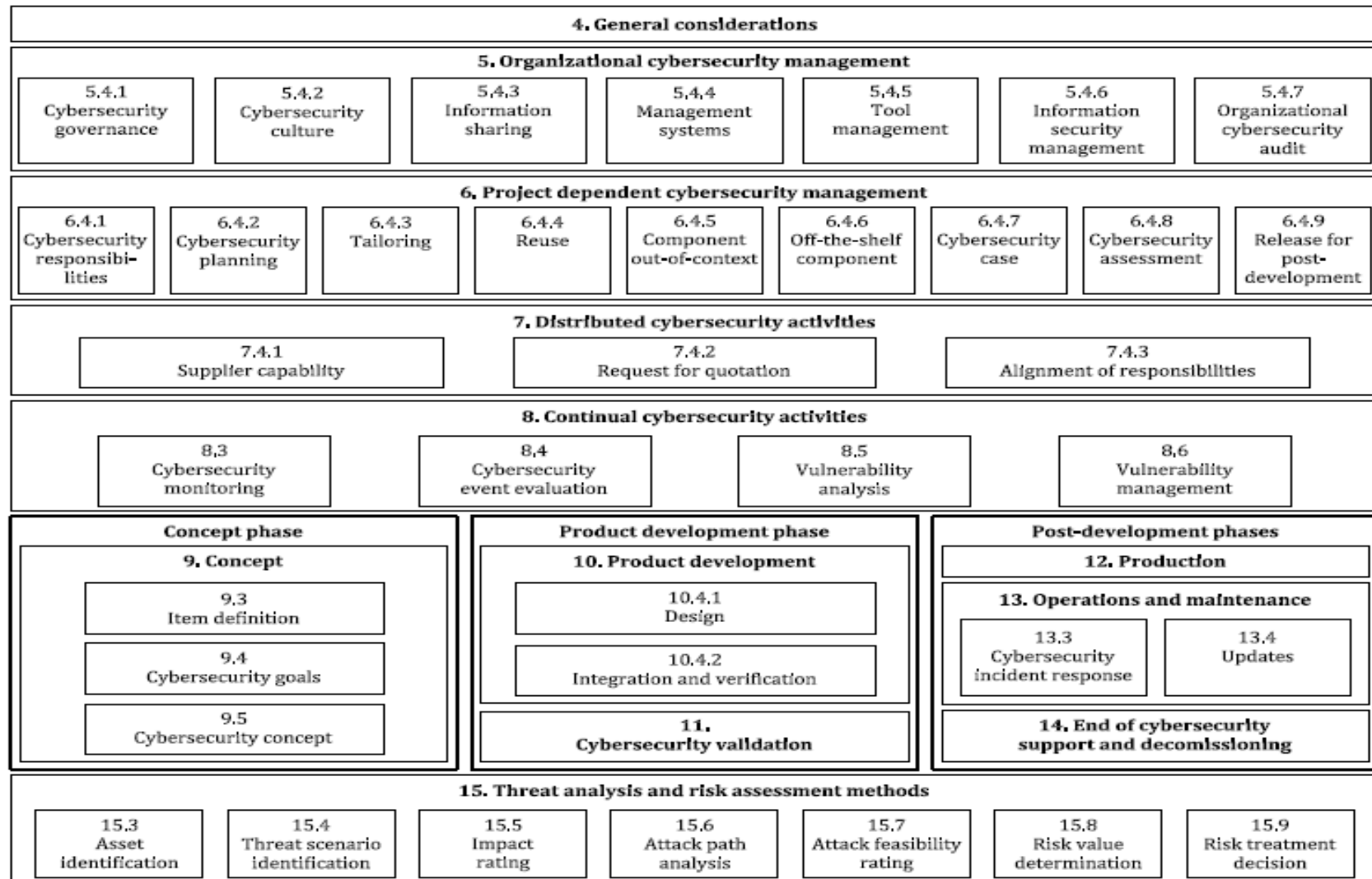
Definition : Cybersecurity

LGE Internal Use Only

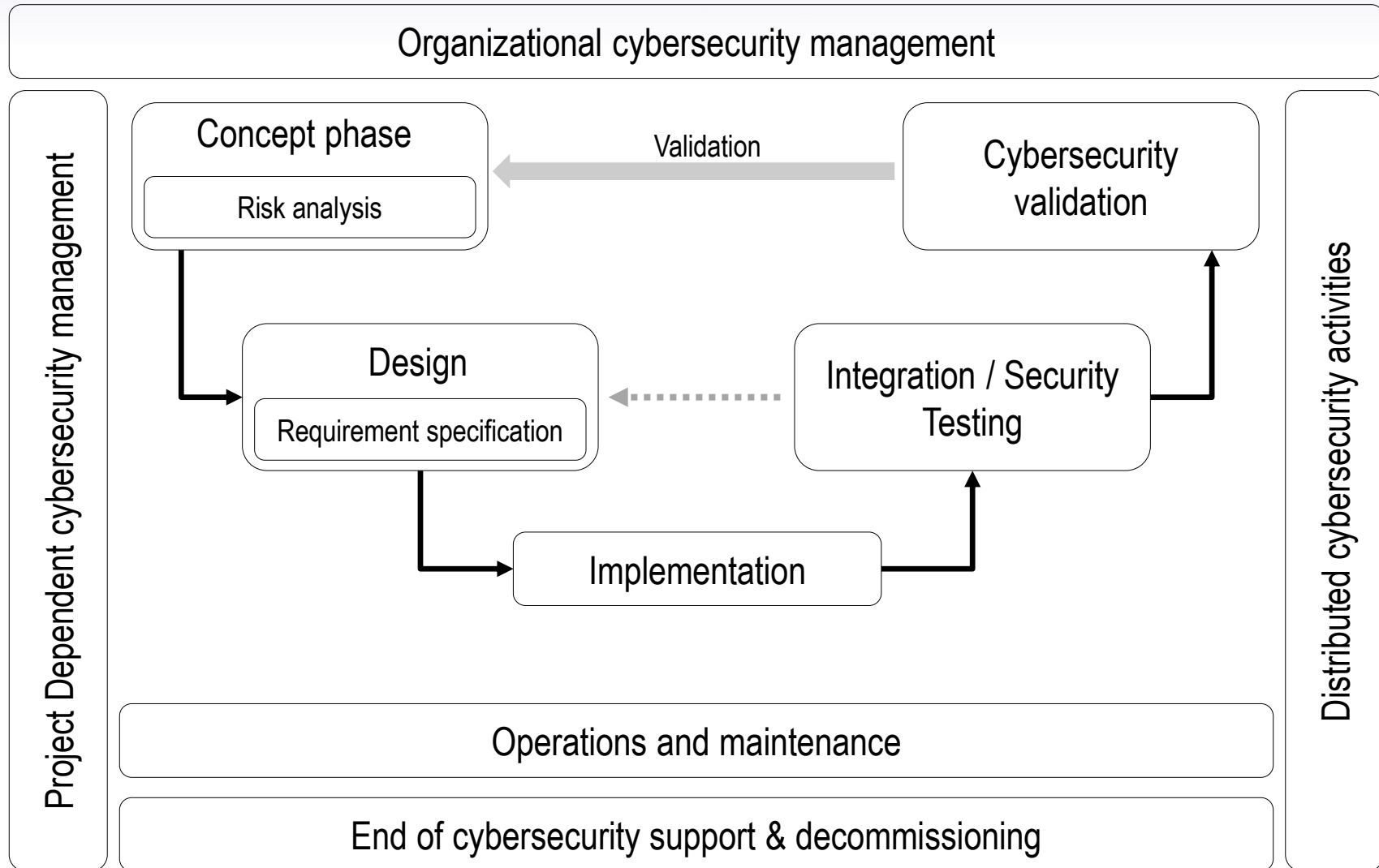
- Cybersecurity is the collection of measures that can be used to protect the assets



- Specifies engineering requirements for cybersecurity risk management regarding concept, product development, production, operation, maintenance and decommissioning of electrical and electronic (E/E) systems in road vehicles, including their components and interfaces.



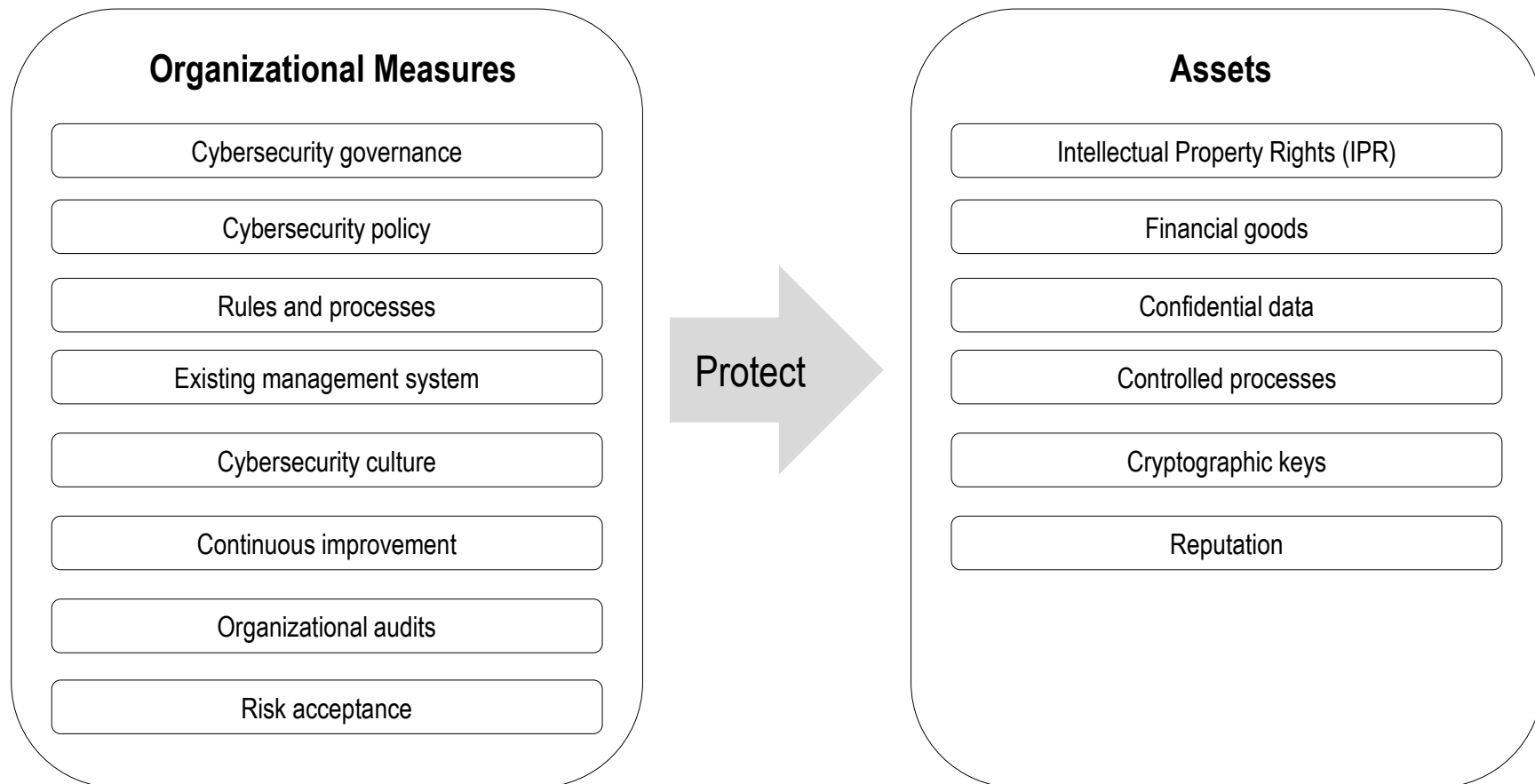
Cybersecurity Engineering According to ISO/SAE 21434



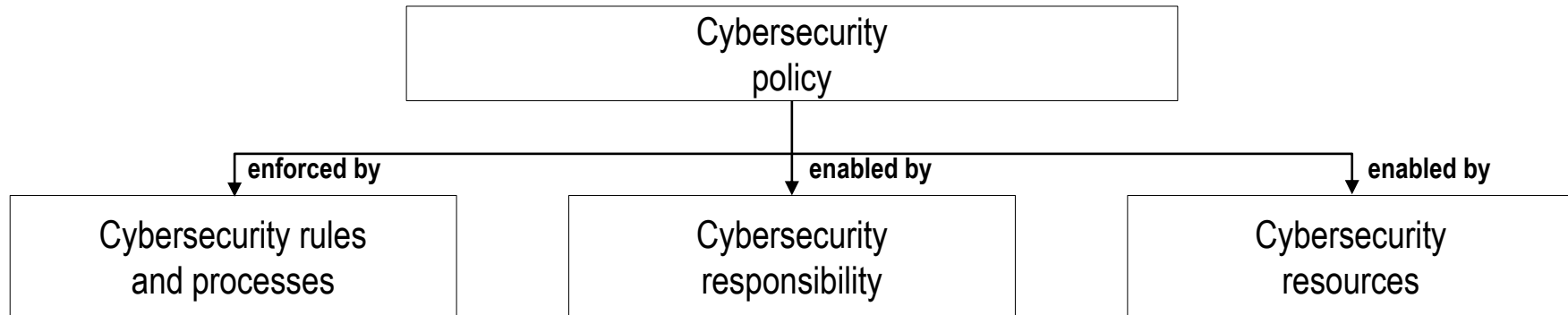
[Clause 5] Organizational Cybersecurity Management

[Clause 5] Organizational Cybersecurity Management

- Organization shall institute and maintain cybersecurity governance and cybersecurity culture, including cybersecurity awareness management, competence management and continuous improvement [to enable cybersecurity engineering](#)
- Organizational measures have to be in place to protect the assets and are applied in a defense-in-depth approach



- The set of policies, processes, and procedures including responsibility & resources that an organization uses to manage and protect its information assets from cyber threats



- The basis for the implementation of ISO/SAE 21434
- Cybersecurity policy includes
 - Acknowledgement of road vehicle cybersecurity risk
 - Executive management's commitment to manage the corresponding cybersecurity risks

General Organization

- Support the [awareness](#) of road vehicle cybersecurity risks

OEM Management

- Commitment to [take care](#) about the risks
- Definition of the [cybersecurity management scope](#)

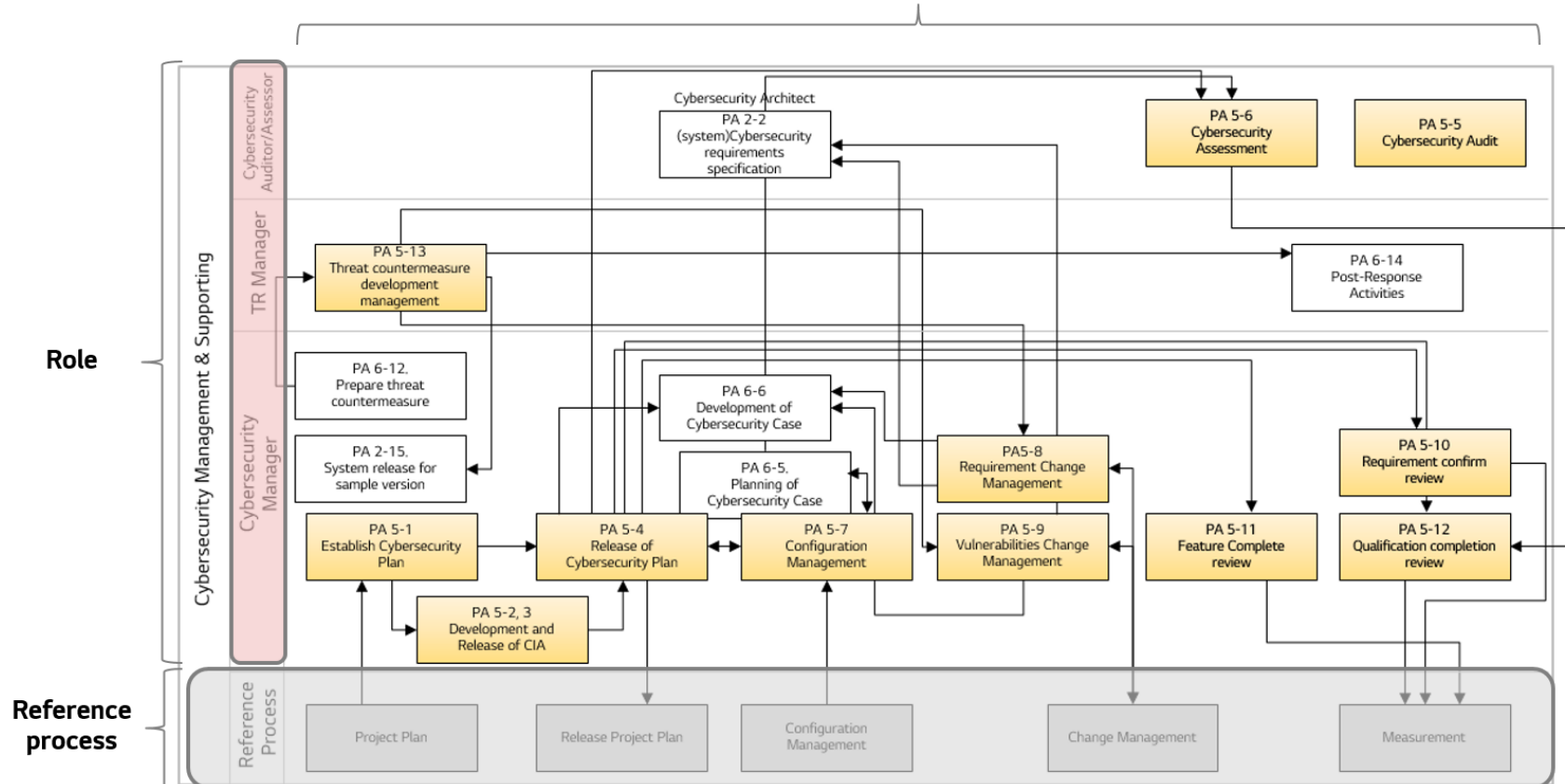
External stakeholders

(e.g. third party supplier, end customer)

- Support [harmonized interface](#) to the OEMs policy

- Cybersecurity interests shall interact with the existing management system
- Adoption of cybersecurity to the existing processes throughout the complete lifecycle
 - Concept, product development, production, operation, maintenance, decommissioning

Relationship flow between CSMS activities



- Clear definition of roles and responsibilities
 - E.g. Project Manager / Cybersecurity Manager / Vulnerability Tester / Incident Response Manager

e.g)

Role	Responsibility	Required Expertise	Remarks
Cybersecurity manager	• Cyber security project management • Establish and manage cybersecurity policy • Create and manage cybersecurity plans • Monitoring and coordinating cybersecurity status and risk/issue • Report and escalation cybersecurity key issues or risk • Support and coordination cybersecurity issues with Buyer • Plan and prepare audit/assessment • Manage cybersecurity case	• 3 years experience in cybersecurity	• Should be a different person with Functional Safety Manager

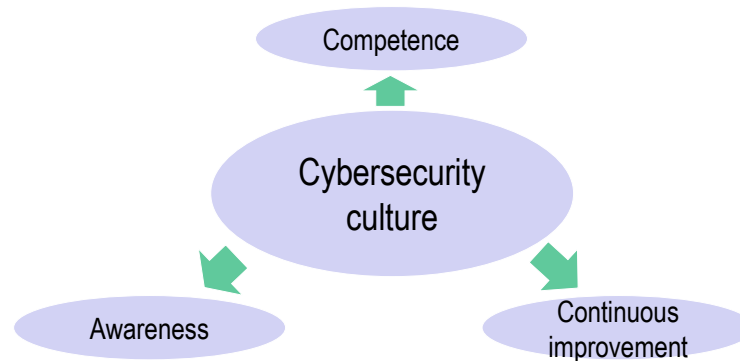
- Personnel assigned to security-related processes shall hold relevant competence being gained by training, experience, seminars, conferences, certifications
 - Unexperienced personnel needs to be supervised
- Resources should be managed with appropriate tools

- Organization shall foster and maintain a strong cybersecurity culture
- Cybersecurity culture generates a common understanding about what cybersecurity means within the company

Table B.1 — Examples of weak and strong cybersecurity culture

Examples indicative of a weak cybersecurity culture	Examples indicative of a strong cybersecurity culture
Accountability for decisions related to cybersecurity is not traceable.	The process ensures that accountability for decisions related to cybersecurity is traceable.
Performance (of the implemented functionality or feature), cost or schedule take precedence over cybersecurity.	Cybersecurity and safety have the highest priority.

- Awareness of cybersecurity culture can be achieved by training, internal project reviews, lessons learned, lifecycle assessment by external or internal auditor, peer assessment
- Evidence can be provided by records of trainings, assessment reports, audit reports



- “Need to know” base
- To share information can be based on:
 - Types of information that can be shared
 - Approval processes for sharing
 - Requirements for redacting information
 - Rules for source attribution
 - Types of communications for specific parties
 - Vulnerability disclosure procedure
 - Requirements for receiving party on handling for highly sensitive information

Information

Documents

- Templates
- Mail communication
- Process descriptions

Project data

- HW & SW IPRs
- Change history
- Personal data
- Test results

Documentation

- Internal
- External
- Press release
- Authority related

Market

- Research results
- Market strategies
- Customer data

- Cybersecurity audit shall be performed independently to judge whether the organizational processes achieve ISO/SAE 21434 (CSMS)
- Persons that perform the audit can be internal or external to the organization
- Performed periodically to improve process (OEM may require process evidence from suppliers in the supply chain)

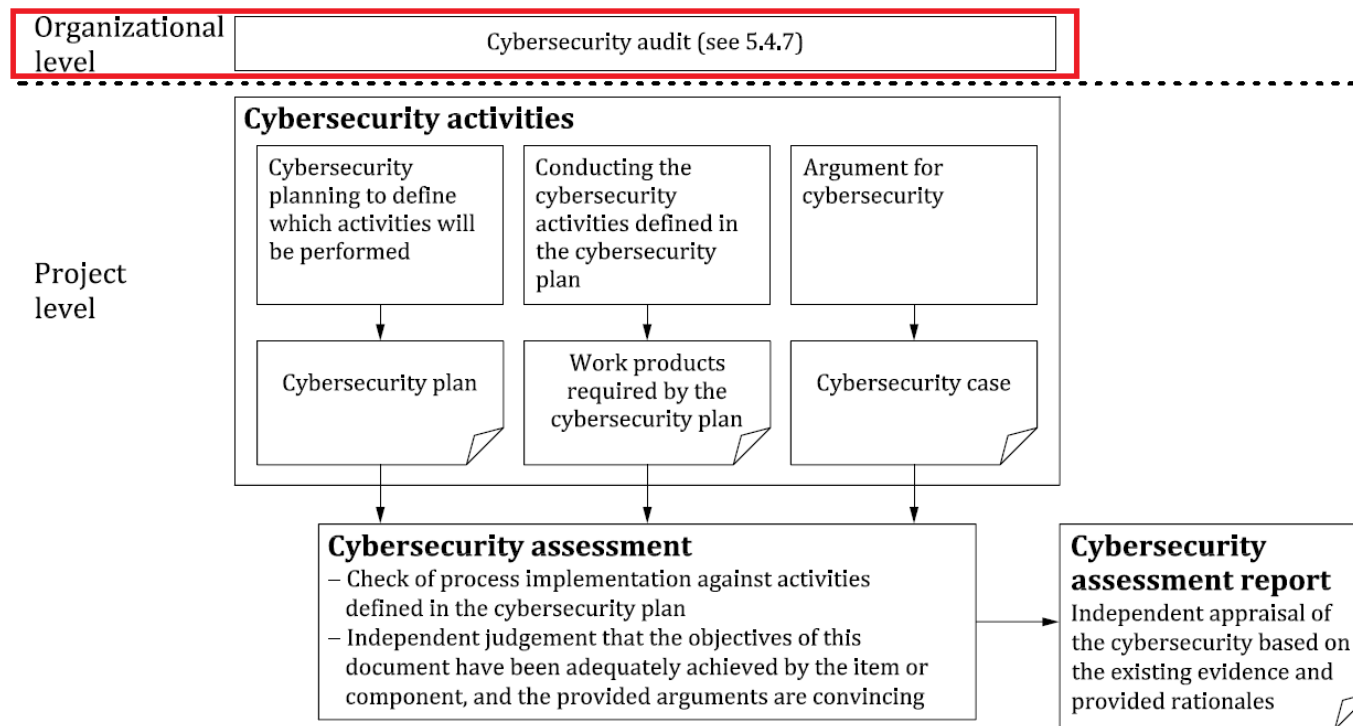


Figure 7 — Cybersecurity assessment in relation to other cybersecurity activities

[Clause 6] Project Dependent Cybersecurity Management

[Clause 6] Project Dependent Cybersecurity Management

- Regarding the management of cybersecurity development activities for a specific project
- The objectives of this clause
 - Assign the responsibilities regarding the project's cybersecurity activities
 - Plan the cybersecurity activities
 - Create cybersecurity case
 - Perform cybersecurity assessment
 - Release for post development

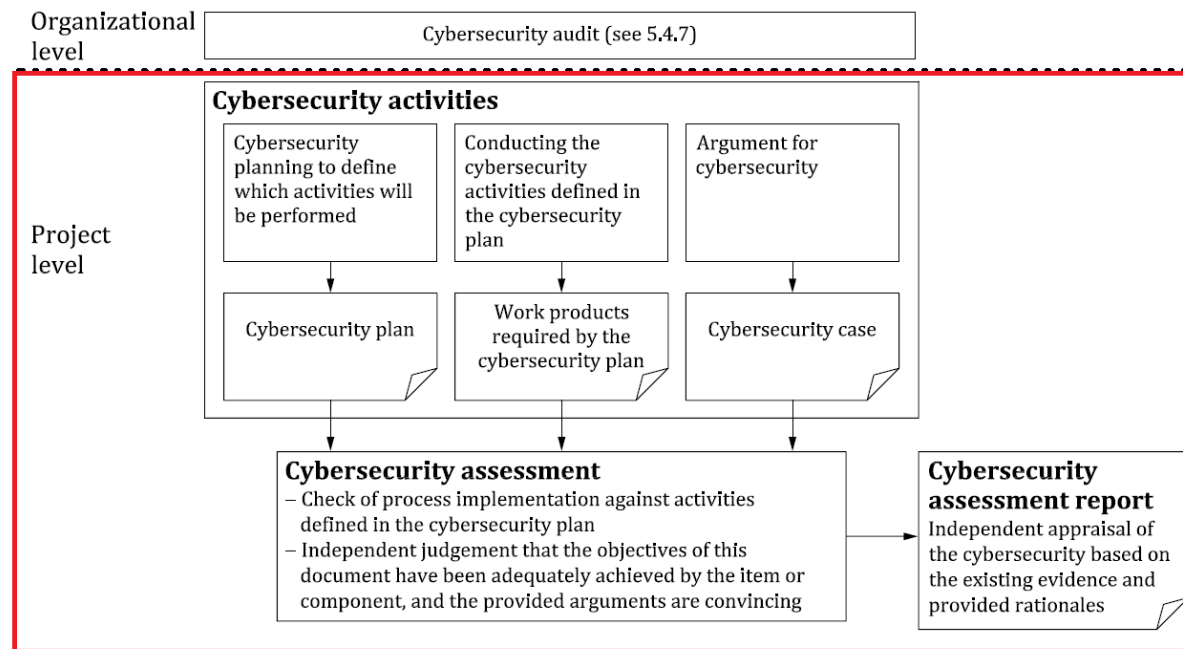


Figure 7 — Cybersecurity assessment in relation to other cybersecurity activities

- Cybersecurity planning has to be integrated and synchronized with the existing project planning
- Contents of cybersecurity plan
 - Defines
 - Objective of each cybersecurity activity
 - Scope and dependencies on other activities or information
 - Tailored cybersecurity activities
 - Assignment of personnel and responsibilities to roles
 - Required resources for performing an activity
 - Starting point or end point, and the expected duration of an activity
 - Development and implementation of the security requirements
 - Verification and validation activities (CAL dependent methods)
 - Identification of the work products to be produced
- Plus, all activity plan for product life cycle

- For each cybersecurity activity a responsible person must be assigned
- The responsible person must be competent for the assigned task
- Persons are assigned to roles, defined in organizational cybersecurity management
- Important part of the cybersecurity plan

e.g)

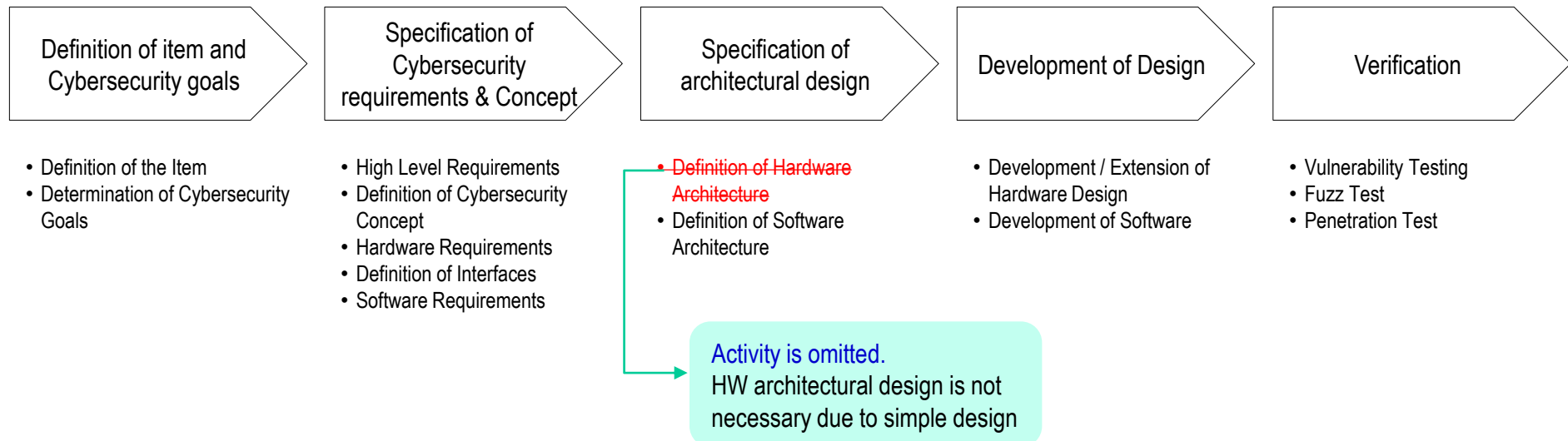
Name	Role	Company/Department	Expertise, Competences, Remarks	Contact
XXX	Cybersecurity manager	• Cyber Security Management Unit	• 10 years experience in cybersecurity management • ISO 21434 experience in various project	• +82 ... • xxx#@lge.com

- Rationale must be provided for each tailoring :
 - The activity has been omitted or
 - The activity is performed in a different manner than previously described

*Activities which are performed by another entity are not seen as tailored

- Rationales for tailored processes are also work products (one of evidence for cybersecurity assessment)

e.g)



- Reuse here is the usage of an existing component with respect to cybersecurity functionalities
- What is definition criteria of “Reuse of a component”??
 - Criteria : SW Change should be under 10% ??, No operational environment change??

Component Name	Related Requirement (ID)	SW Modification (Y/N)	Detail of SW Change (%) - Guide : Synchronization rate (over 90%)	Modification of Operational Environment (Y/N)	Detail of Operational Environment change - OS / Chipset / NW Interface (Ethernet to CAN) - Gas <-> Electric Car - Etc	Influence on other modules (Y/N)
----------------	--------------------------	-----------------------	--	---	--	----------------------------------

Asset change (Y/N)	Asset name modified (Add/delete)	Threat scenario changed (Y/N)	Details of Modified threat scenario (Before / After)	Damage scenario changed (Y/N)	Details of Modified damage scenario (Before / After)	Review result in overall impact analysis
--------------------	----------------------------------	-------------------------------	--	-------------------------------	--	--

Related work product	Missing work product / work product to be modified
----------------------	--

Vulnerabilities have been detected

Reuse

Analysis confirmed that it is feasible to reuse an existing design element with no or only minor modifications

- Component Out of Context is the usage of a component which is developed without a specific target application by a third party and provides cybersecurity features

Component Name	Related Requirement (ID)	Vendor name	Details of assumptions on intended use/context with component feature	related work products	Missing work product / work product to be modified
----------------	--------------------------	-------------	---	-----------------------	--

Details of cybersecurity claims	Dtails of impact on the function behavior	Cybersecurity Interface Agreement (Y/N)
---------------------------------	---	---

Component has been deprecated

Out of context

Usage of an already existing IC which has been developed for one specific vehicle

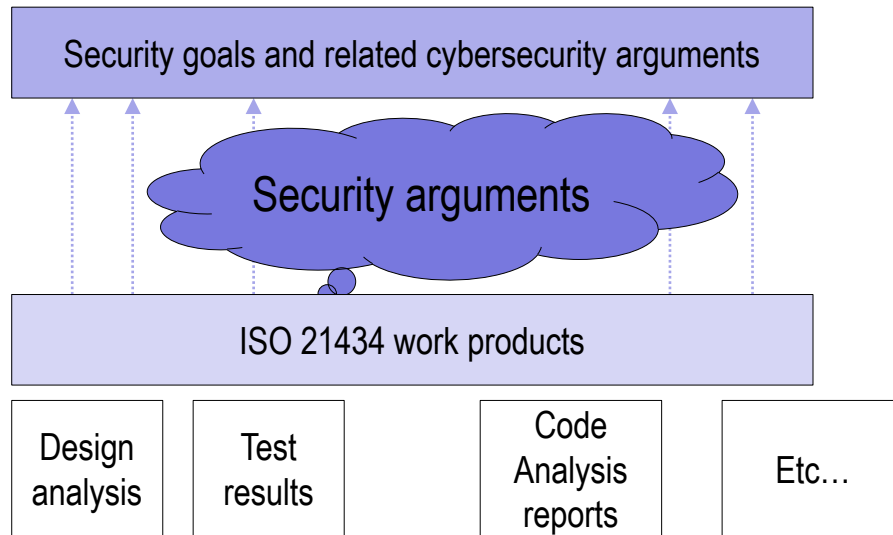
- An Off-the-Shelf Component is a mass market product that might not be designed for specific requirements of vehicle cybersecurity

Component Name	Related Requirement (ID)	Vendor name	Version Name	Influence on other modules and the cybersecurity context (Y/N)	Details of influence on other modules and the cybersecurity context	Definition of implementation details	Applicability to the existing activities
OSSVS - Availability of vulnerability test	EM - Availability of vulnerability test	SCA - Availability of vulnerability test	Related work product	Missing work product / work product to be modified	Detail of impact on the functional behavior		

External supplier has been changed

Off-the-shelf
Usage of existing Mass Market map material

- The Cybersecurity Case shall be created to provide the argument, supported by work products, for the achieved degree of cybersecurity



Provide arguments to claim that

- The cybersecurity requirements are met
- The cybersecurity functions / measures are implemented
- The necessary cybersecurity integrity has been achieved

Evaluation of whether the work products referenced in the cybersecurity case :

- Are traceable from one to another
- Have no contradictions within or between work products
- Have no open issues

A security argument link the supporting evidence with the overall Security Goals of the item.

It is necessary to provide process and product argument.

Usually done in office tools such as Word, Excel

- The Cybersecurity Case is summary of the cybersecurity related activities including results

- The scope of a cybersecurity assessment :
 - Cybersecurity plan and all work products identified in the cybersecurity plan
 - Treatment of the cybersecurity risks
 - Appropriateness and effectiveness of implemented cybersecurity controls and cybersecurity activities performed for the project (can be judged by using prior reviews that were performed for verification purposes)
 - The rationales, if provided, that demonstrate the achievement of the objectives of ISO 21434

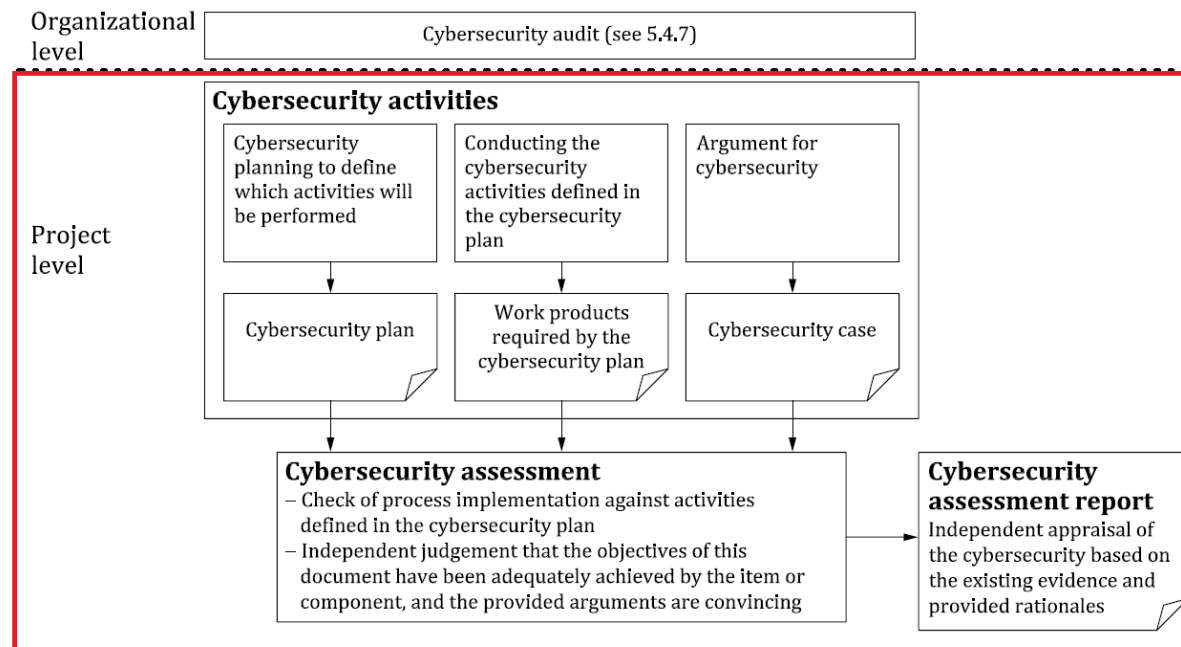
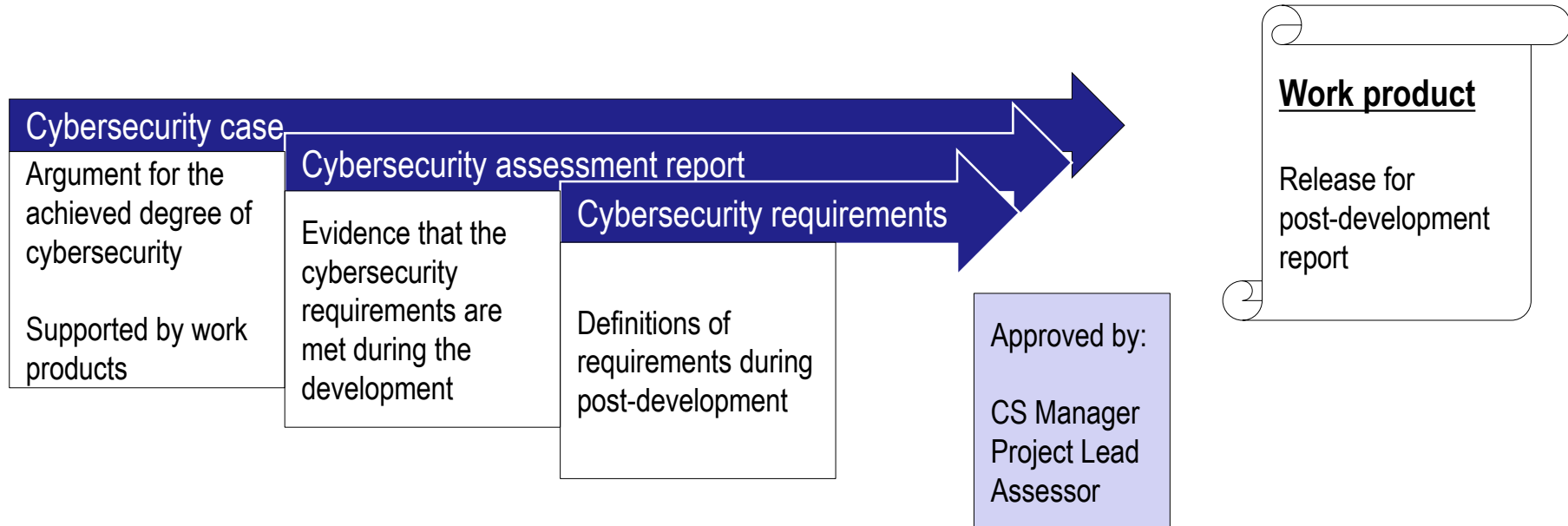


Figure 7 — Cybersecurity assessment in relation to other cybersecurity activities

- Cybersecurity Assessment must be performed prior to post-development release
- If the cybersecurity assessment is not performed, the rationale must be reviewed independently and documented in the cybersecurity case
 - Rationale : TARA results / Item, component complexity / process-defined criteria
- Cybersecurity assessment can be :
 - Performed in incremental steps to facilitate an early resolution of identified issues
 - Repeated or supplemented, e.g. due to a change, when a previous cybersecurity assessment provided a negative recommendation, or when a vulnerability is discovered
- Person executing the assessment might be from :
 - The quality assurance department within the organization
 - A different team or department or
 - An independent third party
- Assessment report shall include a recommendation for acceptance / rejection or conditional acceptance

- Release for post-development report is the final statement that the cybersecurity measures have been sufficiently implemented and the development process has been successfully completed
- In case the release is not granted, the criticized activities have to be repeated

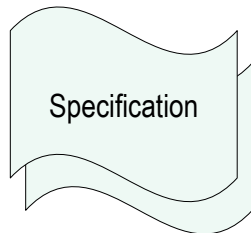
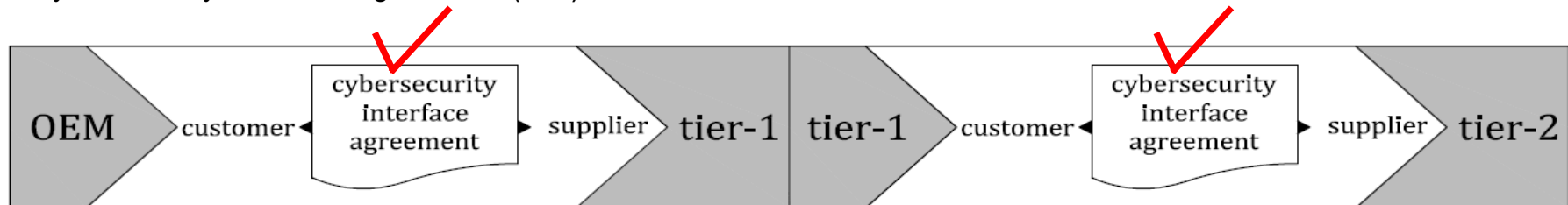


[Clause 7] Distributed cybersecurity activities

[Clause 7] Distributed cybersecurity activities

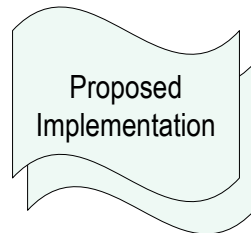
LGE Internal Use Only

- Procedure for Distributed cybersecurity activities
 - Supplier selection based on record of capability
 - Secure production
 - Regular cybersecurity training
 - Previous Assessment Report
 - CSMS certification, etc..
 - Request for Quotation
 - Cybersecurity goals, set of cybersecurity requirements / Expectation of CIA / Request to conform ISO 21434
 - Cybersecurity Interface Agreement (CIA)



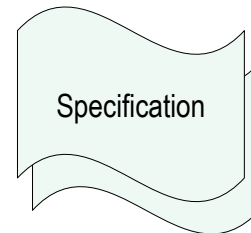
Specification

What do I want?



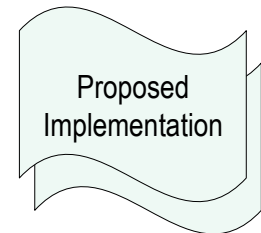
Proposed
Implementation

What can I provide?



Specification

What do I want?

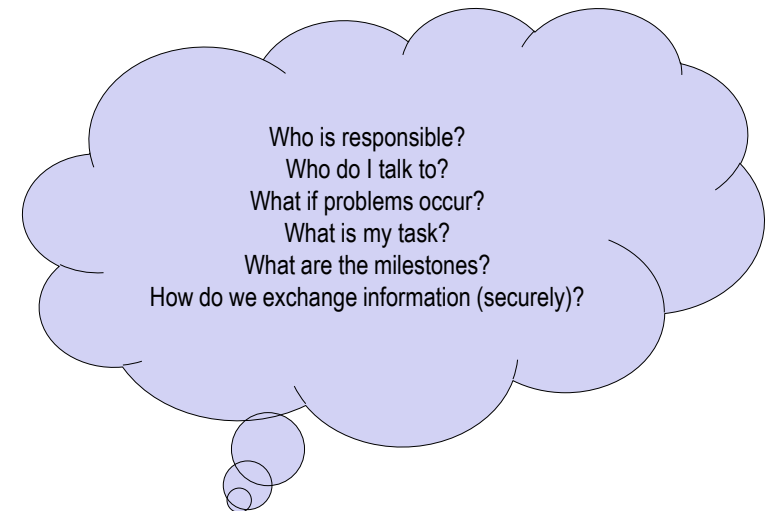


Proposed
Implementation

What can I provide?

- A customer and a supplier shall specify the distributed cybersecurity activities in a cybersecurity interface agreement
- CIA including :
 - Appointment of customer's and supplier's points of contact regarding cybersecurity
 - Identification of cybersecurity activities that are to be performed by customer and supplier
 - Information and work products to be shared
 - Milestones regarding the distributed cybersecurity activities
 - Definition of the end of cybersecurity support for the item or component

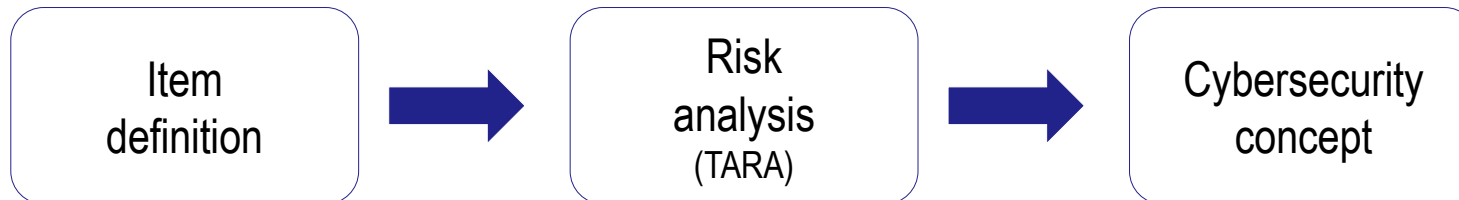
Phase	Work product	Doc ref.	Supplier					Customer					Level of confidentiality	Comment
			R	A	S	I	C	R	A	S	I	C		
Concept	Item definition													
	Treat analysis and risk assessment													
	Cybersecurity concept													
	Verification report of cybersecurity concept													
Product development	Cybersecurity specification													



R : Responsible
 A : Accountable
 S : Support
 I : Inform
 C : Consult

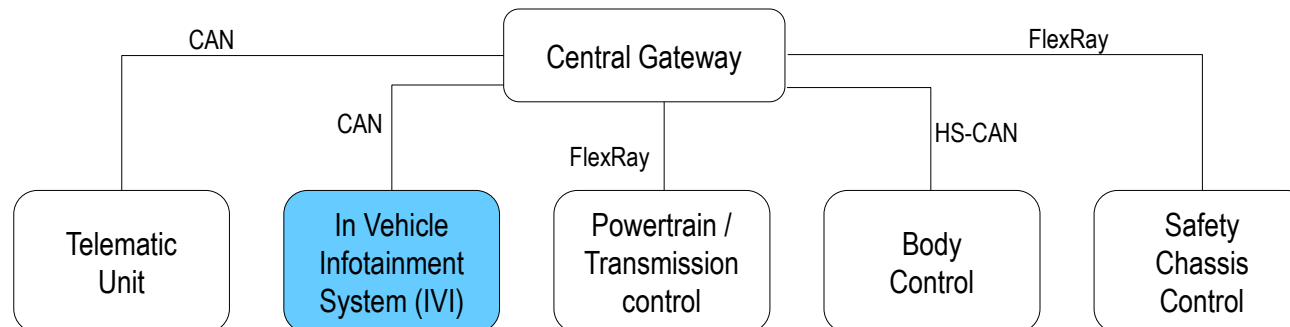
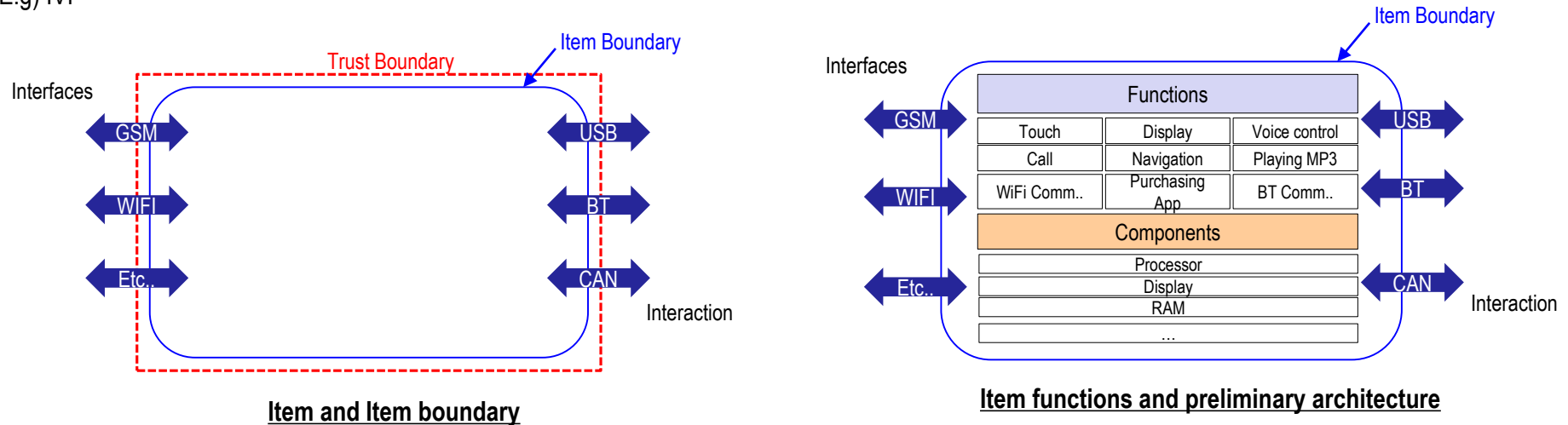
[Clause 9] Concept phase

- Objectives of Concept
 - Define the item, its operational environment and their interactions in the context of cybersecurity
 - Specify cybersecurity goals and cybersecurity claims
 - Specify the cybersecurity concept to achieve cybersecurity goals
- Concept phase activities
 - OEM defines functions, security goals and a first architecture



- Item functions, Item boundary, Preliminary architecture shall be identified
- Operational environment shall be described, provides supplemental information for analysis activities of the TARA
- Item definition serves as input for the TARA (Threat Analysis and Risk Assessment)

E.g) IVI



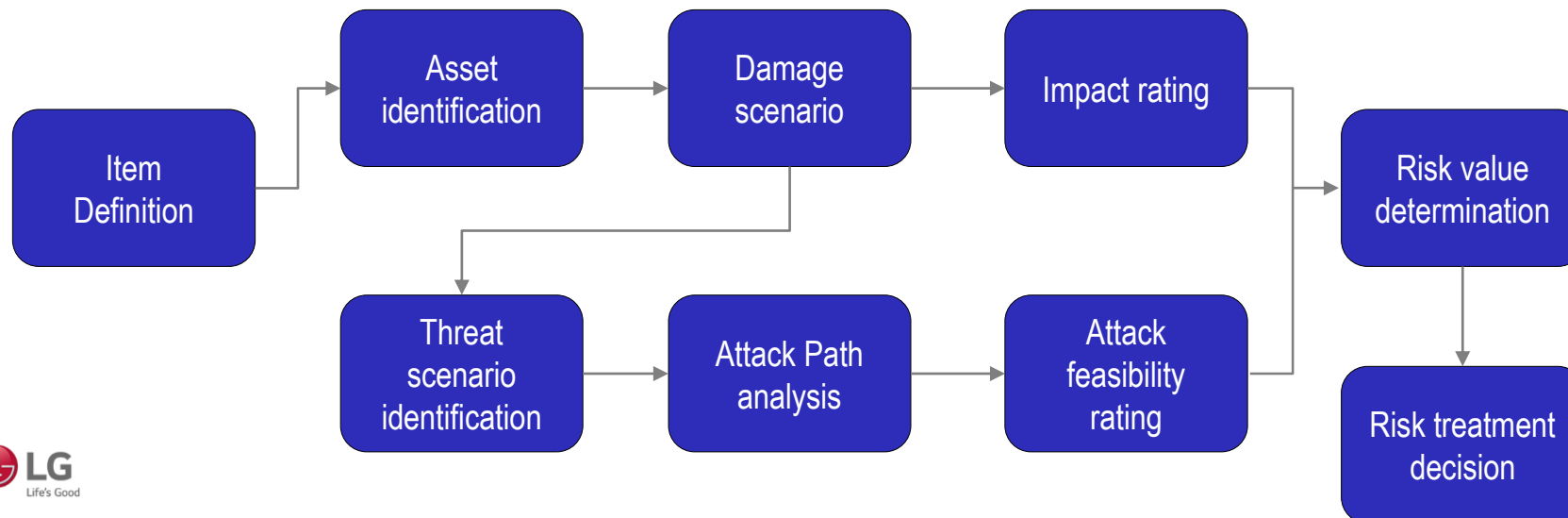
Item on vehicle level / Operational Environment

- TARA based on the item definition shall be performed that involves :

- Asset identification
- Damage & Threat scenario identification
- Impact rating
- Attack path
- Attack feasibility rating
- Risk value determination

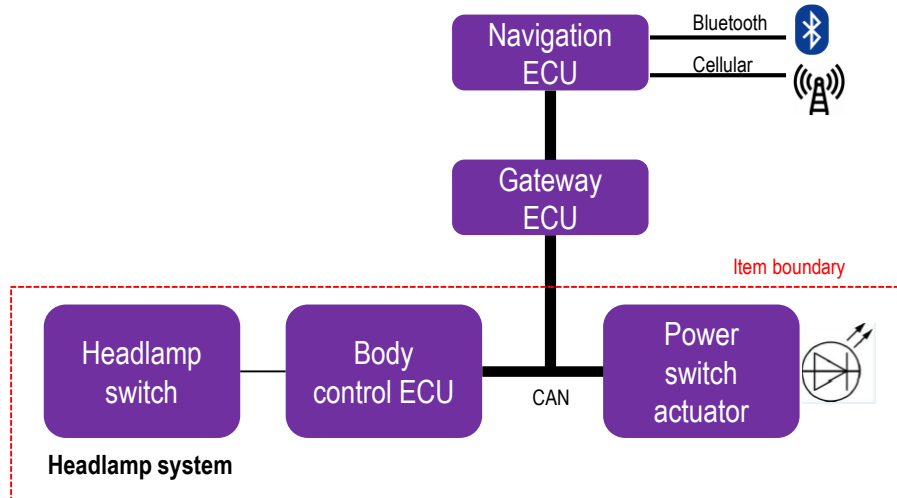
- TARA Steps

- TARA is a formalized step-by-step approach, which is essential for any following lifecycle



- Asset : object that has value, or contributes to value
- Asset has one or more cybersecurity properties whose compromise can lead to one or more damage scenarios
- Or Asset is simply something that needs to be protected by cybersecurity techniques

e.g) Headlamp system

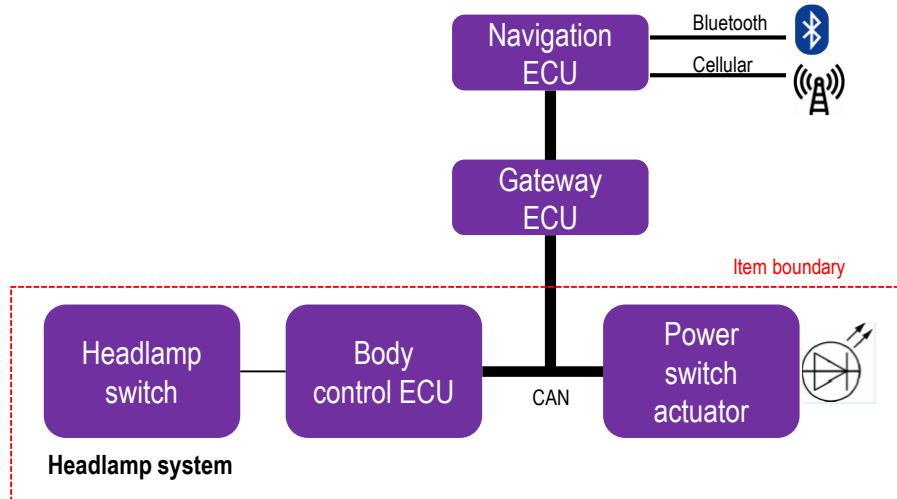


Headlamp Switch

- Considered function:
- Use power switch actuator to turn the head lamp OFF and ON
- The body control unit sends a message over the CAN bus to the Power Switch Actuator of the Head Lamp
- Gateway controls access to the CAN bus for other ECUs

Asset	Confidentiality	Integrity	Availability
Data communication (lamp request)	-	X	X

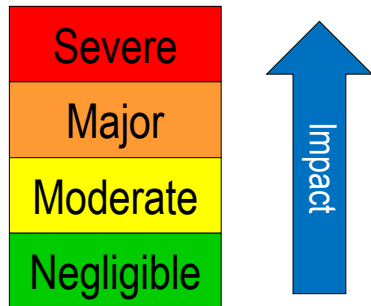
- Damage scenario can include :
 - Relation between the functionality of the item and the adverse consequence
 - Description of harm to the road user and/or
 - Relevant assets



Asset	Confidentiality	Integrity	Availability	Damage scenario
Data communication (lamp request)	-	-	X	Vehicle cannot be driven at night, because the headlamp function was inhibited while parked.
	-	X	-	Front collision with a narrow stationary object caused by unintended turning-off of headlamp during night driving at medium speed

Impact rating :

- Assess the damage scenarios against adverse consequences for stakeholders
- Depends on the point of view
 - *Stakeholder is a person or organization that can be affected by a damage scenario



The following impact categories have at least to be considered :

- Safety impact**
 - injuries range from **life-threatening** (severe) to moderate and **no injuries** (negligible)
- Financial impact**
 - financial damage from **catastrophic** (severe) to **irrelevant** (negligible) to the stakeholder
- Operational impact**
 - operational damage from **not working** (severe) to **indiscernible** (negligible) degradation
- Privacy impact**
 - privacy from **highly sensitive** (severe) information to **inconveniencies** (negligible)

- Each damage scenario is assessed regarding Safety, Financial, Operational and Privacy (S,F,O,P) impact which results in four values

Damage scenario	Safety	Financial	Operational	Privacy
Vehicle cannot be driven at night, because the headlamp function was inhibited while parked.	Negligible	Negligible	Major	Negligible
Front collision with a narrow stationary object caused by unintended turning-off of headlamp during night driving at medium speed	Severe	Major	Major	Negligible

- Negative actions need to be identified that lead to a damage scenario in a threat scenario
- The identification of threat scenarios :
 - Is a result of a team work, not by a single person
 - Uses a brainstorming-based approach

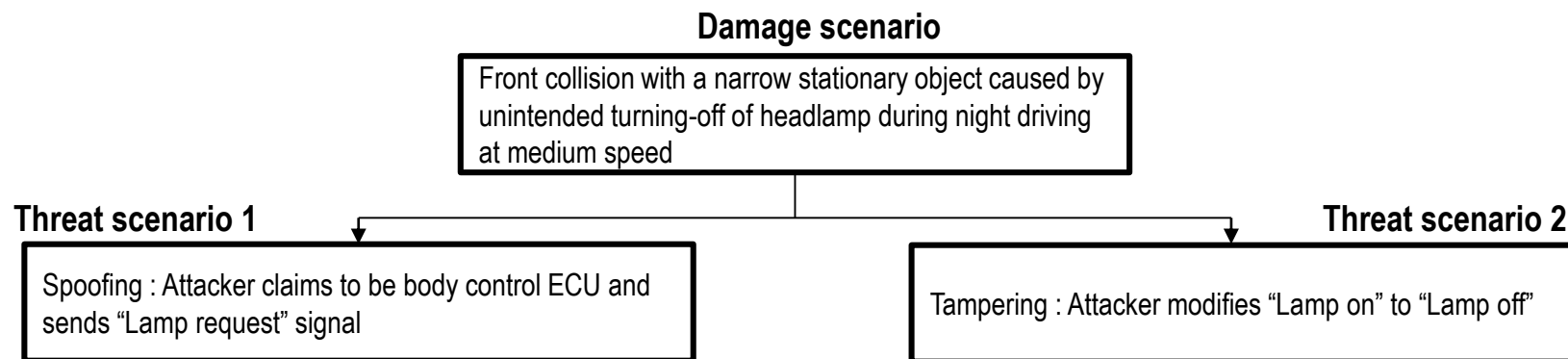
▪ STRIDE

Threat	Description
S poofing	Pretending of a false identity
T ampering	Manipulation of data
R epudiation	Denying an illegal action
I nformation Disclosure	Revealing sensitive information
D enial of Service	Making unavailable to its intended users
E levation of Privileges	Perform an unauthorized action

▪ ...

STRIDE helps to consider multiple threats from different points of view.

STRIDE is based on observation and experience.
→ Certain threats are more prevalent than others



- Identifying steps for the execution of a threat scenario (= attack path)

Necessary actions for a threat scenario to become real

Threat scenario 1

Spoofing : Attacker claims to be body control ECU and sends "Lamp request" signal

Attack Path 1a

Attacker compromises navigation ECU from cellular interface

Attack Path 1b

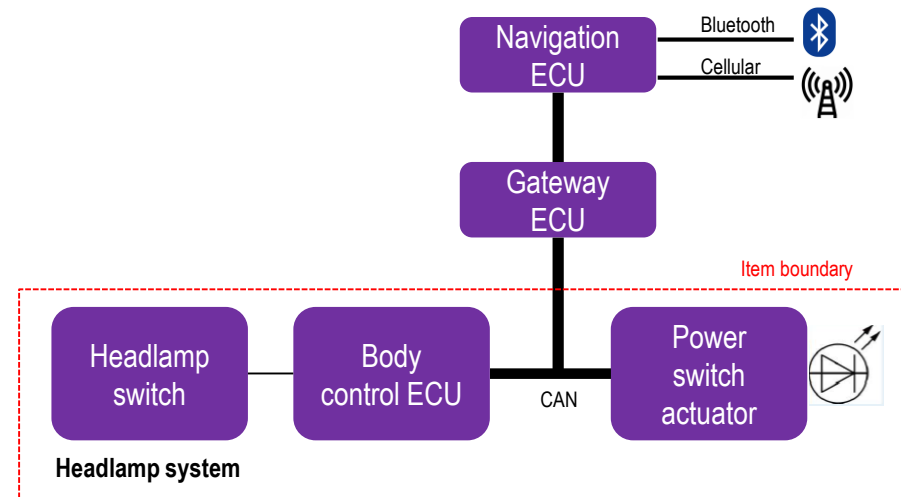
Compromised navigation ECU transmits malicious control signals

Attack Path 1c

Gateway ECU forwards malicious signals to power switch actuator

Attack Path 1d

Malicious signals spoof the lamp request (OFF)



- The rating is based on these categories :

- High** : (The attack path can be accomplished utilizing) low effort
- Medium** : medium effort, **Low** : high effort, **Very low** : very high effort

* Kinds of attack feasibility rating approach

- Attack potential-based approach
- CVSS-based approach
- attack vector-based approach

→ Different methods can lead to different results.
One method shall be used for the rating of each attack path

Attack potential-based approach

Attack Path 1a

Attacker compromises navigation ECU from cellular interface

Attack Path 1b

Compromised navigation ECU transmits malicious control signals

Attack Path 1c

Gateway ECU forwards malicious signals to power switch actuator

Attack Path 1d

Malicious signals spoof the lamp request (OFF)

Elapsed time		Specialist expertise		Knowledge of the item or component		Window of opportunity		Equipment	
Enumerate	Value	Enumerate	Value	Enumerate	Value	Enumerate	Value	Enumerate	Value
≤1 day	0	Layman	0	Public	0	Unlimited	0	Standard	0
≤1 week	1	Proficient	3	Restricted	3	Easy	1	Specialized	4
≤1 month	4	Expert	6	Confidential	7	Moderate	4	Bespoke	7
≤6 months	17	Multiple experts	8	Strictly confidential	11	Difficult/none	10	Multiple bespoke	9
>6 months	19								

$$= 4+6+7+1+0 = 18 \rightarrow \text{Medium}$$

Attack feasibility rating	Values
High	0 - 9
Medium	10 - 13
Low	14 - 19
Very low	20 - 24
	≥ 25

Element	Description
Elapsed time	Time to identify a vulnerability and develop and apply an exploit
Expertise	Capabilities of the attacker, relative to their skill and experience
Knowledge of the item	Amount of information the attacker can acquire
Window of opportunity	Discover the target, access to a target, exploit works on the target, time to perform the attack on a target
Equipment	Tools the attacker has available to execute the attack

- Determination of the **risk** of a **threat scenario** based from the **impact** of the associated damage scenario and **the attack feasibility** of the associated attack paths
- Risk values can be determined utilizing risk matrices **defined by the organization**



		Attack feasibility			
		very low	low	medium	high
Impact rating	severe	2	3	4	5
	major	1	2	3	4
	moderate	1	2	2	3
	negligible	1	1	1	1

- Drive risk value on each S,F,O,P
- Risk value could be **highest value** among risk values on Safety, Financial, Operational and Privacy

Damage scenario	Safety	Financial	Operational	Privacy
Front collision with a narrow stationary object caused by unintended turning-off of headlamp during night driving at medium speed	Severe	Major	Major	Negligible



Attack feasibility rating	Values
High	0 - 9
Medium	10 - 13
Low	20 - 24
Very low	≥ 25



		Attack feasibility			
		very low	low	medium	high
Impact rating	severe	2	3	4	5
	major	1	2	3	4
	moderate	1	2	2	3
	negligible	1	1	1	1

Risk value

S : 4
F : 3
O : 3
P : 1

- For each threat scenario, considering its risk values, risk treatment options could be :
 - Avoiding the risk (by removing the risk sources)
 - Reducing the risk (e.g. by reducing the factors of the attack feasibility)
 - Sharing (Transferring) the risk (e.g. by contracts / insurances)
 - Retaining or Accepting the risk
- Risk treatment decision might affect the mitigation measure for a threat
- Risk treatment according to risk value can be **defined by the organization**

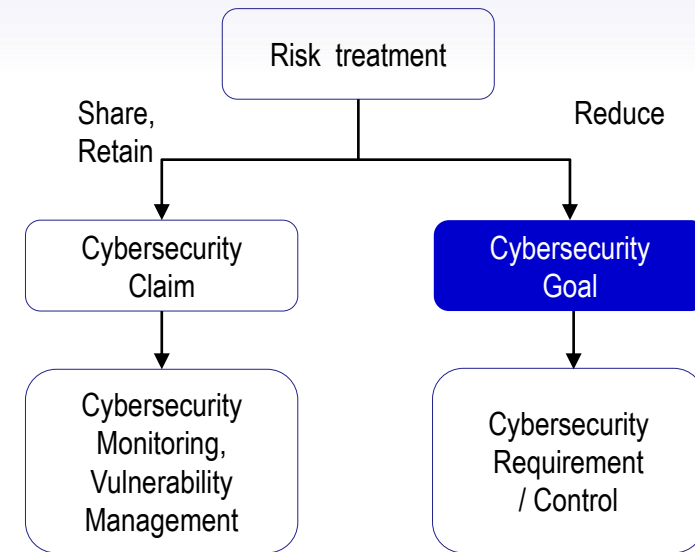


		Attack feasibility			
		very low	low	medium	high
Impact rating	severe	2	3	4	5
	major	1	2	3	4
	moderate	1	2	2	3
	negligible	1	1	1	1

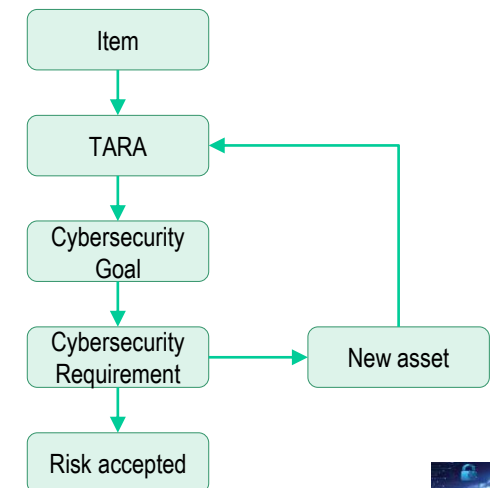
e.g) Risk treatment option to each risk value

Risk value	Risk treatment option
5	avoiding the risk / reducing the risk
4	reducing the risk
3	reducing the risk
2	sharing or transferring the risk
1	accepting or retaining the risk

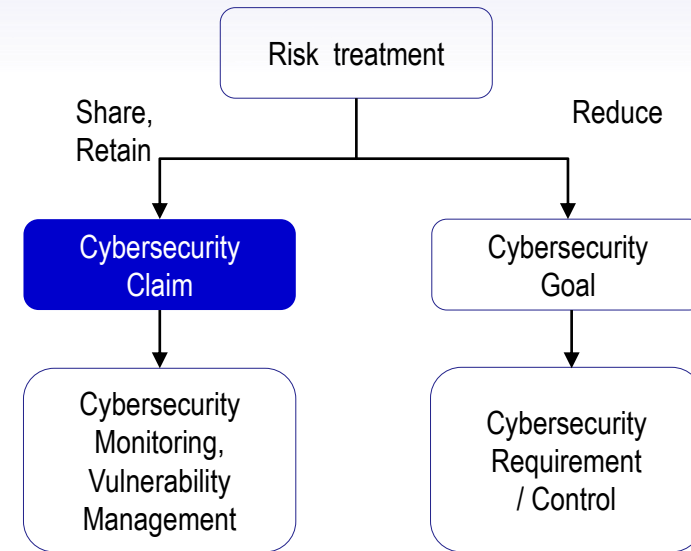
- Cybersecurity goals are the top level security requirement
- The existence of several cybersecurity goals for one item is possible
- One cybersecurity goals can be related to several cybersecurity requirements
- Cybersecurity goals are typically defined by the OEM



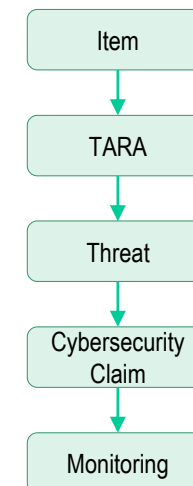
- Relation of terms – Cybersecurity Goal
 - Fact : Data is stored unencrypted
 - Outcome of TARA : loss of privacy is possible (threat), Reduce (risk treatment)
 - Security goal : Protection of stored private data
 - Security requirement : Private data shall be encrypted
 - New asset : Encryption key



- Statement about a risk
- If risk treatment includes :
 - Sharing the risk or
 - Retaining and accepting the risk due to one or more assumptions
- Then one or more cybersecurity claims shall be specified
- Cybersecurity claims can be considered for cybersecurity monitoring



- Relation of terms – Cybersecurity Claim
 - Outcome of TARA : Compromise of library (threat), Share (risk treatment)
 - Security claim : If the library is compromised, then the tier and the OEM share the responsibility by contract. The tier is responsible to perform monitoring activities and vulnerability management
 - Details of security claims shall be part of Cybersecurity Interface Agreement

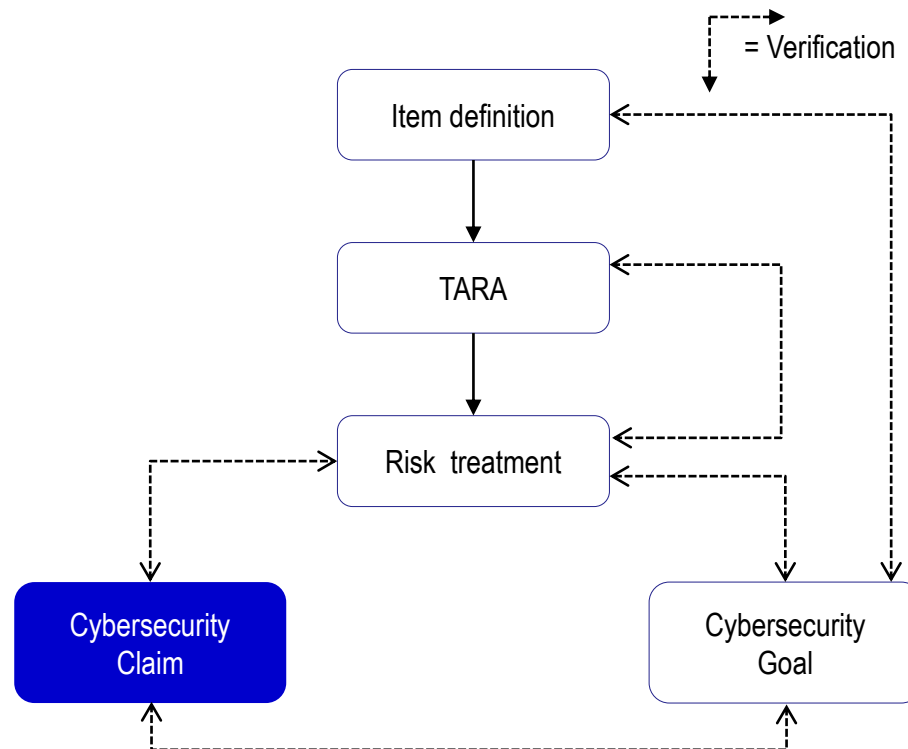


- E.g.1
 - “A risk value of 1 is generally accepted because it’s below the acceptance criteria for risks.”

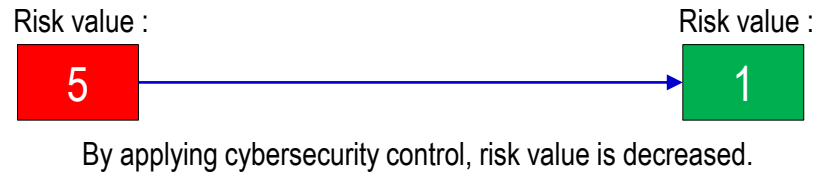
- E.g. 2
 - “Encryption with algorithm DES is sufficient because the following is assumed:
 - a) Attacker is considered as not be a Proficient and does not have knowledge to exploit DES
 - b) Window of opportunity is low: Algorithm needs to be broken during drive in Bluetooth range
 - c) The ECU does not have the resources to handle and calculate higher sophisticated algorithms
 - d) This claim shall be re-evaluated once a year

- **Cybersecurity claim is a description of why a risk is acceptable, including a specification under which condition the risk need to be re-evaluated**

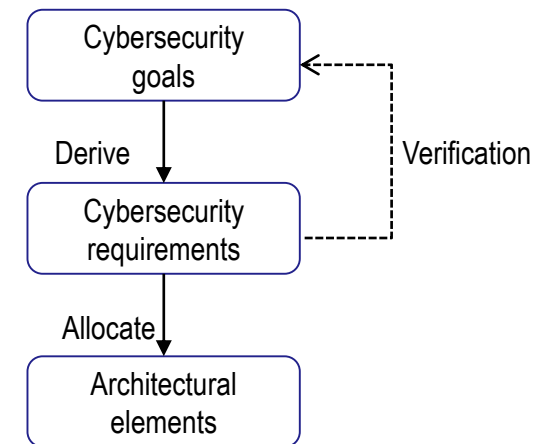
- Assigned/qualified person performs the verification of cybersecurity goals/claims through review
 - Are the cybersecurity goals meaningful and aligned with the item definition?
 - Is the risk treatment decision aligned with the results of TARA? Is this all consistent?
 - Do the cybersecurity goals and claims address the risk treatment decision adequately?
 - Are there any conflict between the cybersecurity goals and claims?



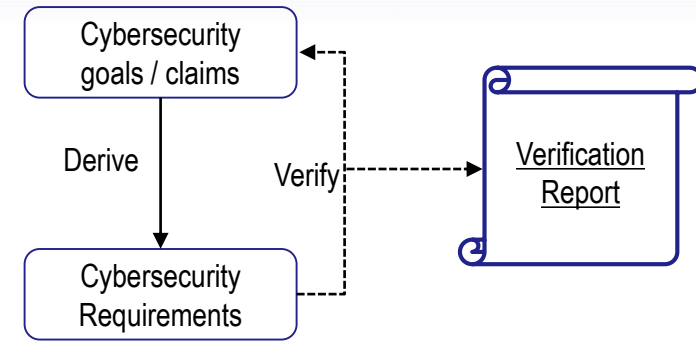
- Define technical and/or operational cybersecurity controls
 - Cybersecurity control : measure that is modifying the risk



- Derive cybersecurity requirements from cybersecurity goals
 - What is the specified functionality?
 - How are interactions between components specified?
 - How are the requirements verified?
 - Are there external dependencies, e.g. requirements for other items?
- Allocate cybersecurity requirements to the item or its components
- Plan the cybersecurity validation to show that cybersecurity goals are achieved



- All cybersecurity requirements need to be verified to show :
 - Consistency with the Cybersecurity Goals
 - Consistency with the Cybersecurity Claims
- The verification is summarized in a Verification Report
- Verification of cybersecurity concept supports the cybersecurity case



- E.g. Cybersecurity concept (Infotainment System)

[...]

3.1 Cybersecurity controls

RQ 4711 : Private data shall be encrypted

RQ 4711.1 : Component shall have sufficient resources to handle encryption

RQ 4711.2 : Encryption keys shall be stored securely

3.2 Cybersecurity requirements – operational environment

RQ 4712 : Identification/authentication for Bluetooth connections prior to data exchange

RQ 4712.1 : Common Bluetooth standard shall be used

3.3 Allocation to item/components

RQ 4711 – supplier shall select appropriate components

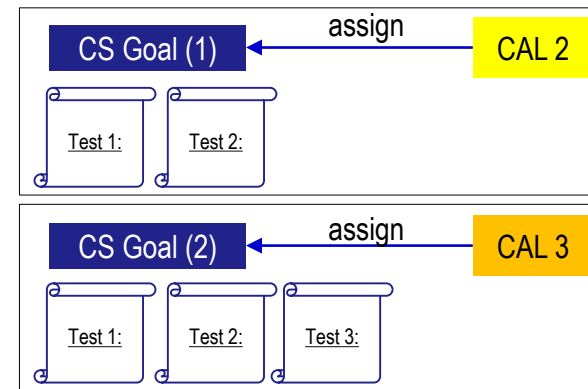
RQ 4712 shall be ensured through “Bluetooth communication” component

- Level of rigor that provides confidence that protection of the assets is adequately developed
- The CAL is assigned to a cybersecurity goal and is inherited by cybersecurity requirements
- Based on the assigned CAL, the rigor of verification activities can be defined

ISO/SAE 21434, Annex E

*attack vector-based approach

		Attack vector			
		Physical	Local	Adjacent	Network
Impact rating	severe	CAL2	CAL3	CAL4	CAL4
	major	CAL1	CAL2	CAL3	CAL4
	moderate	CAL1	CAL1	CAL2	CAL3
	negligible	-	-	-	-



*Higher CALS require higher independency of cybersecurity activities

Table E.3 — Example of level of independence of cybersecurity activities

Activity	Require-ments	Level of independence applies to ^a				Scope
		CAL1	CAL2	CAL3	CAL4	
		I1	I1	I2	I2	
Verification of cybersecurity concept and design activities	[RQ-09-11] [RQ-10-08]	I1	I1	I2	I2	Applies to the highest CAL among the cybersecurity requirements
Verification of the implementation and integration of components	[RQ-10-09]	I1	I1	I2	I2	
Cybersecurity validation	[RQ-11-01]	I1	I1	I2	I2	
Cybersecurity assessment	[RQ-06-27]	—	I1	I2	I3	

^a The notations are defined as follows:

—: no suggestion regarding the independence of this activity;

I1: the activity is performed by a different person in relation to the person(s) responsible for the creation of the considered work product(s);

I2: the activity is performed by a person who is independent from the team that is responsible for the creation of the considered work product(s), i.e. by a person reporting to a different direct superior; and

I3: the activity is performed by a person who is independent, regarding management, resources and release authority, from the department responsible for the creation of the considered work product(s).

Table E.4 — Example of parameters of testing methods

Activity	Require-ments	Testing parameters apply to ^a				Scope
		CAL1	CAL2	CAL3	CAL4	
Functional testing	[RC-10-12] [RQ-11-01]	T1	T1	T2	T2	Applies to the highest CAL among the cybersecurity requirements
Vulnerability scanning	[RC-10-12] [RQ-11-01]	T1	T1	T1	T1	
Fuzz testing	[RC-10-12] [RQ-11-01]	—	T1	T2	T2	
Penetration testing	[RC-10-12] [RQ-11-01]	—	—	T1	T2	

^a The notations are defined as follows:

—: no suggestion regarding testing parameters for this activity;

T1: testing parameter set 1:

— functional testing based on requirements;

— vulnerability scanning for known vulnerabilities;

— fuzz testing with random of selection of inputs;

— penetration testing assuming moderate attacker expertise, knowledge of the item or component and/or resources;

T2: testing parameters set 2:

— functional testing based on requirements and interactions between components;

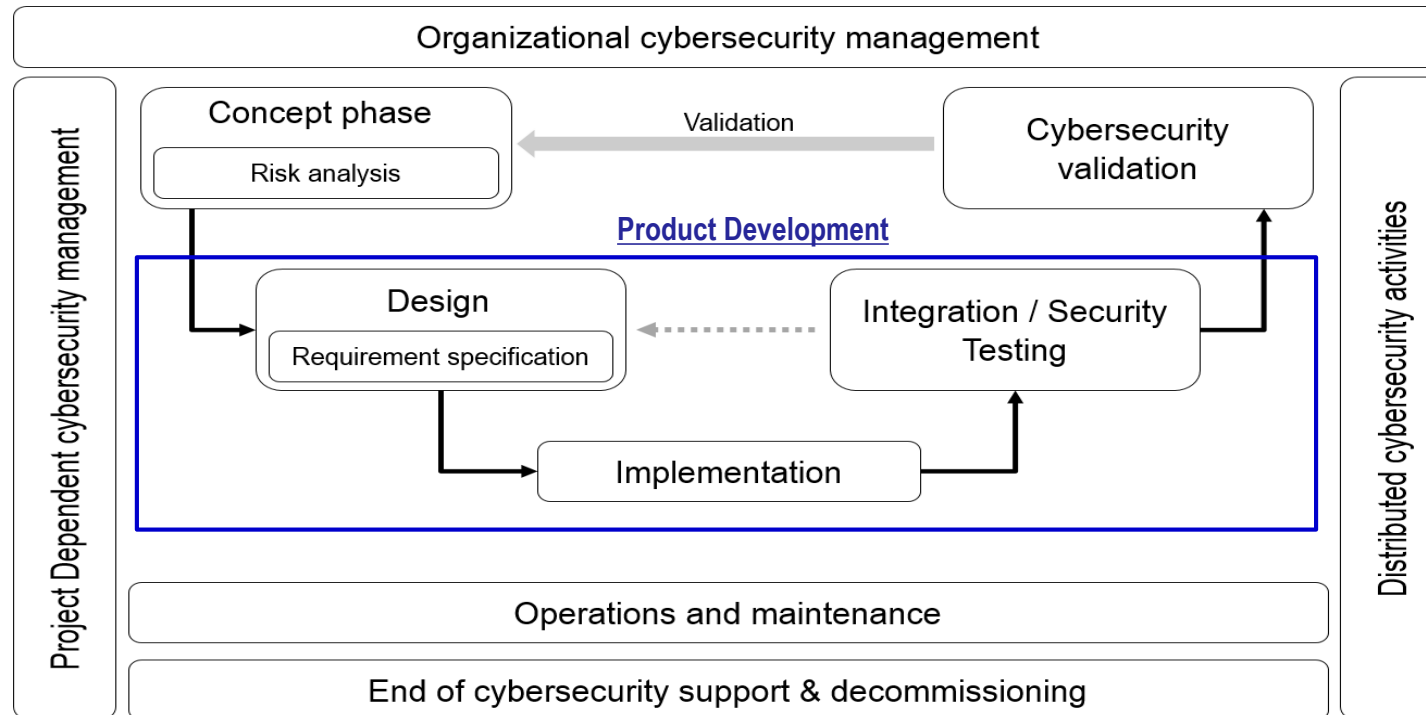
— vulnerability scanning for known vulnerabilities;

— fuzz testing with an increased number of test case iterations and/or adaptive selection of inputs;

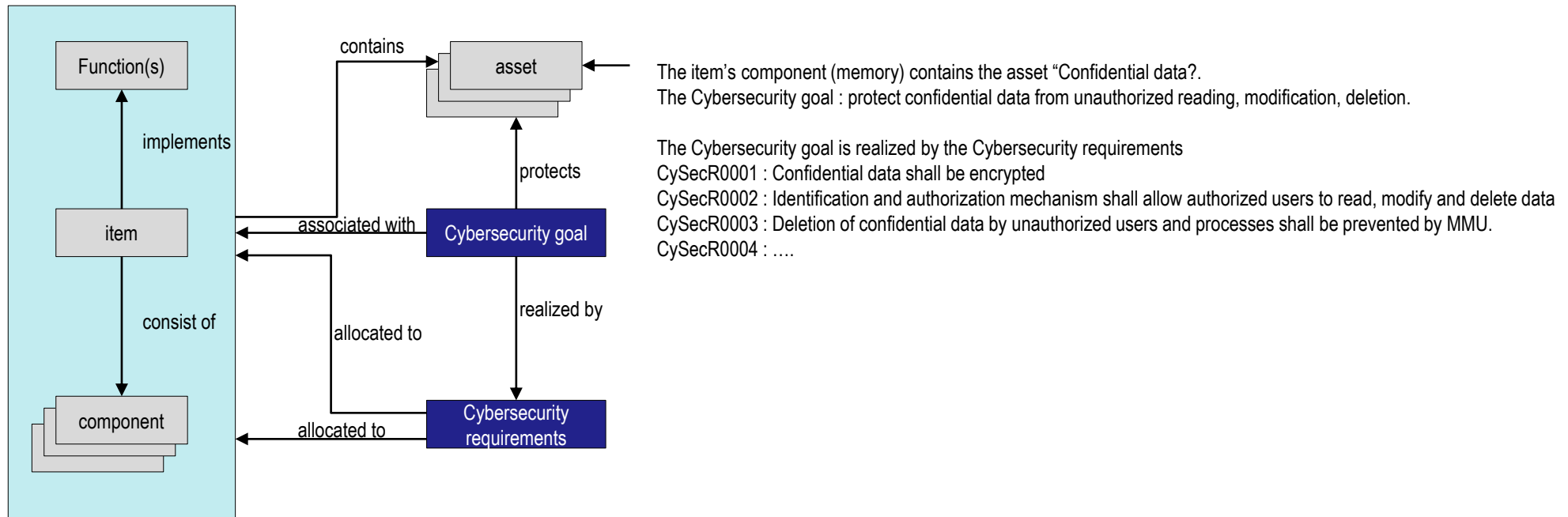
— penetration testing assuming higher attacker expertise, knowledge of the item or component and/or resources.

[Clause 10] Product Development

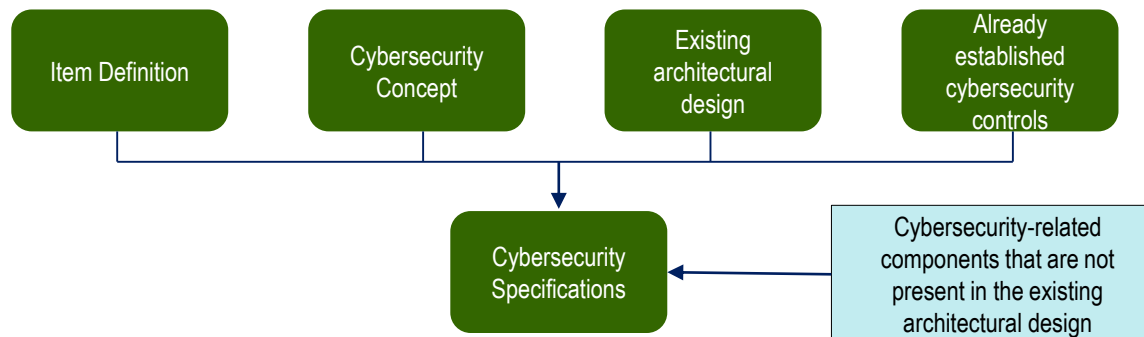
- To fulfil cybersecurity concept :
 - Define cybersecurity specifications
 - Verify that the defined cybersecurity specifications conform to the cybersecurity specifications from higher levels of architectural abstraction
 - Identify weakness in the component
 - Provide evidence that the results of the implementation and integration of components conform to the cybersecurity specifications



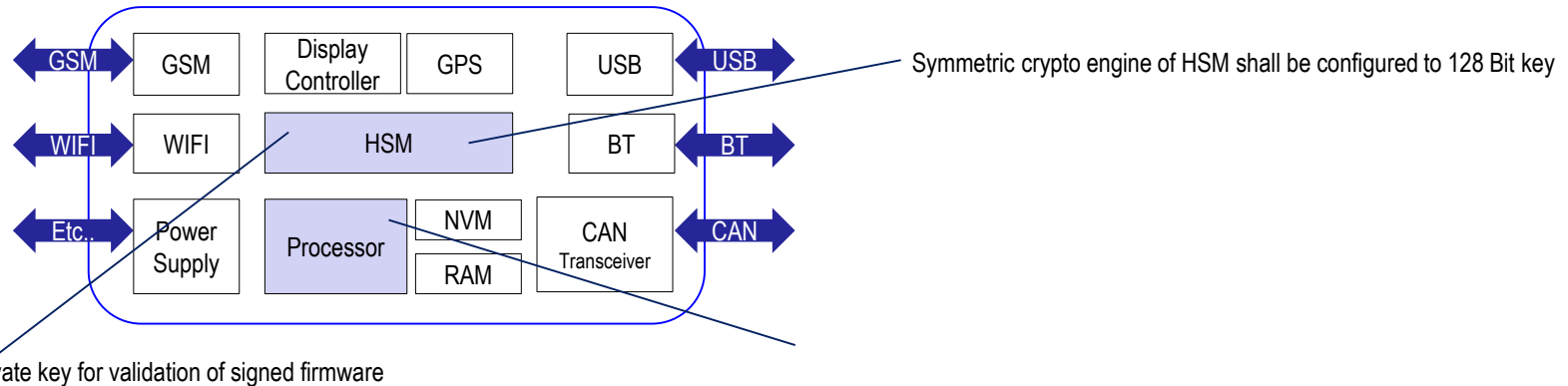
- One Security Goal is realized by at least one cybersecurity requirement



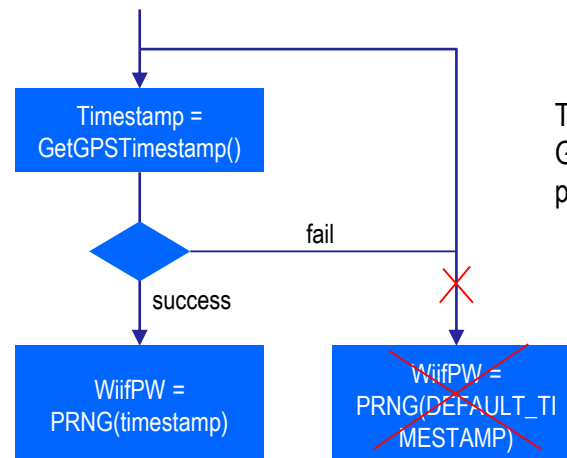
- Inputs for Security Requirements Specification



- The defined cybersecurity requirements shall be allocated to components of the architectural design



- Procedures to ensure cybersecurity after the development of the component shall be specified
 - E.g. Procedures for correct integration and initialization of cybersecurity controls as well as maintaining cybersecurity throughout production



The default WiFi-Password shall be calculated by a PRNG based on the GPS-Timestamp when the device is turned on for the first time in production

- If design, modelling or programming notations or languages are used for the cybersecurity specifications or their implementation, the following shall be considered when selecting such a notation or language
 - Unambiguous and comprehensible definition in both syntax and semantics
 - Support for achievement of modularity, abstraction and encapsulation
 - Support for the use of structured constructs
 - Support for the use of secure design and implementation techniques
 - Ability to integrate already existing components (e.g. library, framework, software component written in another language)
 - Resilience of language against vulnerabilities due to its improper use (e.g. resilience against buffer overflows)

- Criteria for suitable design, modelling or programming languages for cybersecurity that are not addressed by the language itself shall be covered by design, modelling and **coding guidelines**, or by the development environment.

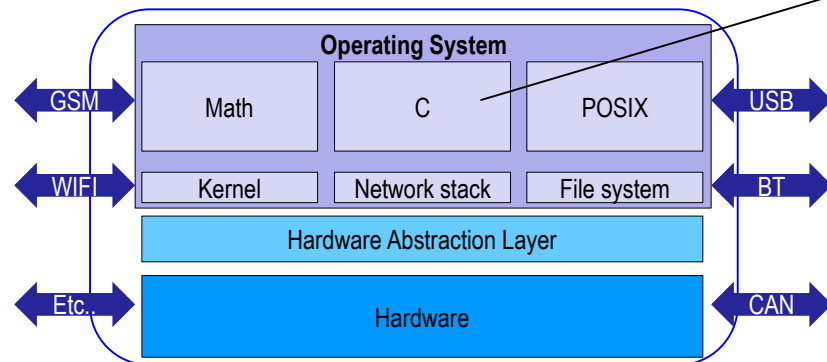
MISRA C:2012**“Guidelines for the use of C language in critical systems”**

ISO/IEC TS 17961:2013
“C Secure”

2016 SEI **CERT C**

Mapping of MISRA C coverage of the "CERT C" / "C Secure" requirements shows that MISRA C already has excellent coverage of those recommendations.

- The architectural design shall be analyzed to identify weaknesses
 - Known weaknesses and vulnerabilities from reused components can be considered
 - Identified weaknesses can be resolved with change to the architectural design without performing a vulnerability analysis



Cybersecurity Agency

Alert (AA84-242AA)

BadAlloc vulnerability – CVE-2021-220477

Technical Details

Integer overflow vulnerability affecting the `calloc()` function in C runtime library

Affected product version

Secure OS 1.0

Mitigation

Contact manufactural for patch

- The defined cybersecurity specifications shall be verified to ensure **completeness, correctness, and consistency** with the cybersecurity specifications from higher levels of architectural abstraction
- Verification methods can include :
 - Review
 - Analysis
 - Simulation
 - Prototyping

- Source code shall :
 - be readable and understandable
 - compile-time complexity analysis
 - result into software which can be tested
 - compiler switch dependent test functions
 - keep the coding guidelines
 - compile-time static analysis
 - fulfil all specified requirements
 - requirement tracking tool

- E.g. for Secure Coding Standards
 - SEI CERT C
 - CERT C++
 - Android Secure
 - SEI CERT Oracle (for java)
 - SEI CERT Perl
 - OWASP Secure Coding Practices – Quick Reference Guide
 - Secure Coding Guidelines for Java SE (Oracle)
 - Secure Coding Guidelines for .NET Framework 3.5 (Microsoft)
 -

- Integration and verification activities shall verify that the implementation and integration of components fulfil the defined cybersecurity specifications
- The integration and verification activities shall be specified considering :
 - The defined cybersecurity specifications
 - Configurations intended for series production, if applicable
 - Sufficient capability to support the functionality specified in the defined cybersecurity specifications
 - Conformity with the modelling, design and coding guidelines, if applicable
- Methods for verification
 - Requirements-based test (Positive and Negative test cases / **Support cybersecurity requirements**)
 - Interface test (Proper functionality / Interoperability / Consistence to interface description)
 - Resource usage evaluation (CPU, Memory utilization / Bus communication load / Timing constraints)
 - Verification of the control flow and data flow (Input validation / Data flow between components)
 - Dynamic analysis (Statement coverage / Branch coverage)
 - Static analysis (**Support security analysis**)
- Test cases can be derived from analysis of requirements, generation and analysis of equivalence classes, boundary value analysis and error guessing based on knowledge or experience

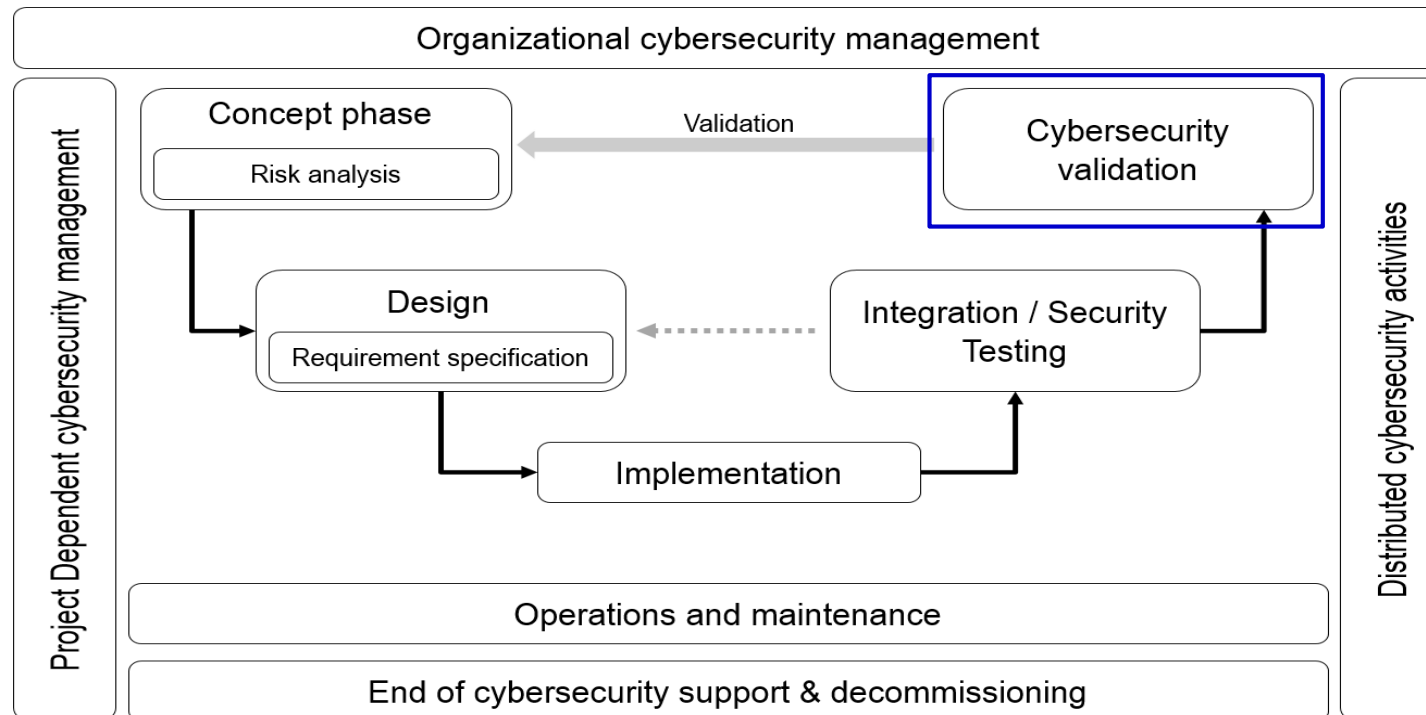
- Testing should be performed in order to confirm that unidentified weaknesses and vulnerabilities remaining in the component are minimized
 - Unnecessary functionalities can contain weakness
 - Testing methods
 - functional testing
 - vulnerability scanning
 - fuzz testing
 - penetration testing
- If testing is not performed, then a rationale shall be provided
 - The rationale can include the following considerations
 - feasibility to access the attack surface of the component
 - capabilities to (directly or indirectly) access the component in combination with compromise of other components
 - simplicity of the component

[Clause 11] Cybersecurity validation

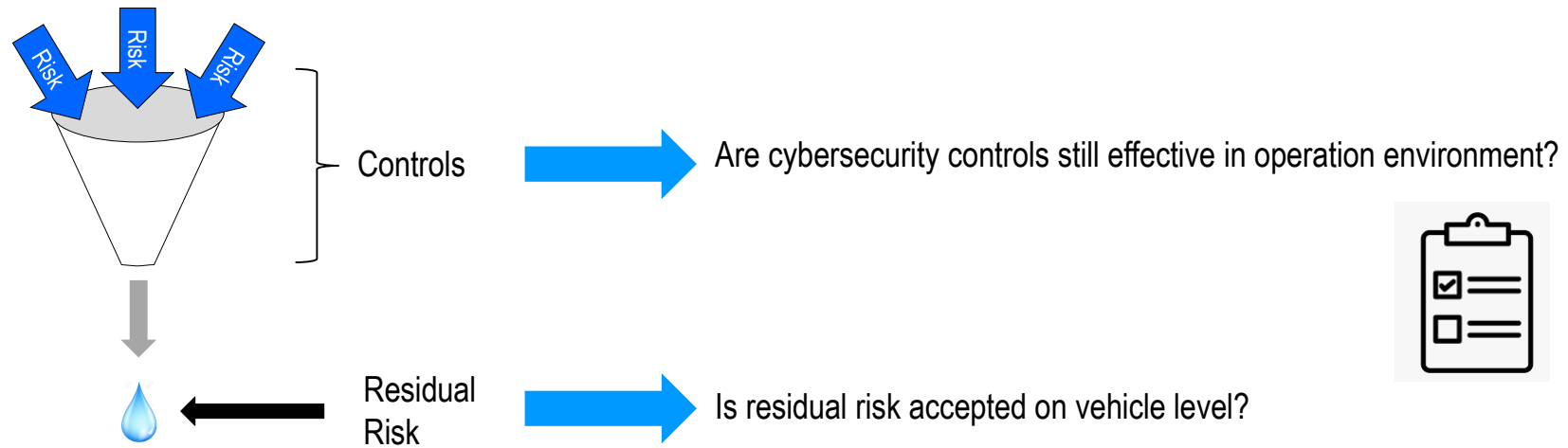
[Clause 11] Cybersecurity validation

LGE Internal Use Only

- Cybersecurity validation has to be performed by OEM on vehicle level
 - To validate cybersecurity goals/claims
 - To confirm the item achieves the cybersecurity goals
 - To confirm that no unreasonable risks remains
- Rationale for the selection of validation activities shall be provided
 - CAL ? / Review of managed risks ? / Operational environment? / Goals, claims? / Penetration test ?



- Confirmation of achievement of cybersecurity goals by reviewing the work products of cybersecurity concept & product development
- Penetration testing to demonstrate adequacy and achievement of cybersecurity goals
 - It is recommended but penetration test on vehicle level might detect additional vulnerabilities
- All managed risks identified during concept and development phase should be taken into consideration
 - Review of managed risks



- The validation report is used as evidence for the OEM that the product has been developed securely
 - Version of product
 - Rational for selection for validation activities
 - Summary of validation test results
- Vulnerability assessment – Example IVI

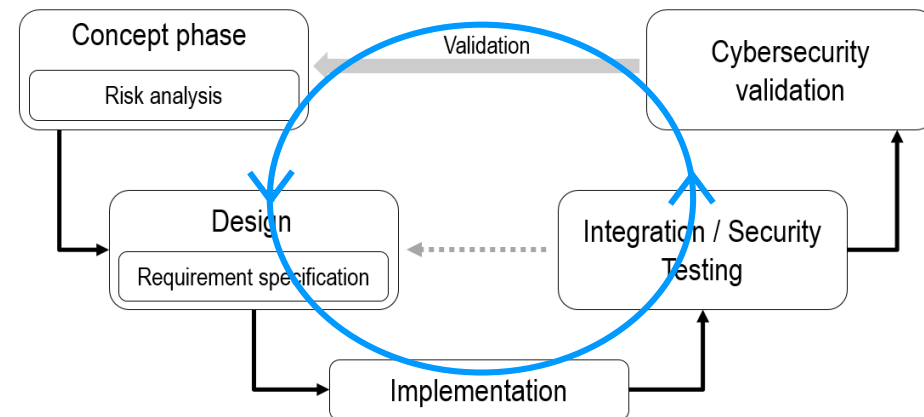
Finding xxx :
An attacker can crash IVI functionality by sending invalid data over OBD

Vulnerability analysis

- Where does this vulnerability come from?

Vulnerability management

- Assessment of risks
- Vulnerability elimination
- Risk treatment decision



Necessary lifecycle phases have to be repeated until vulnerability is fixed

[Clause 12] Production

- Objectives
 - Apply the cybersecurity requirements for post-development
 - Prevent the introduction of vulnerabilities during production

- Production control plan including :
 - Post-development requirements
 - Production tools and equipment
 - Cybersecurity controls preventing unauthorized alteration
 - Verification methods for cybersecurity requirements for post-development

- Cybersecurity post-development requirement
 - After production, diagnostic interfaces are no longer needed
 - Diagnostic interfaces can be an attack vector, solution could be :
 - Sealed hardware plug
 - New firmware flash without code to access JTAG
 - The privileged account is no longer needed → Remove account

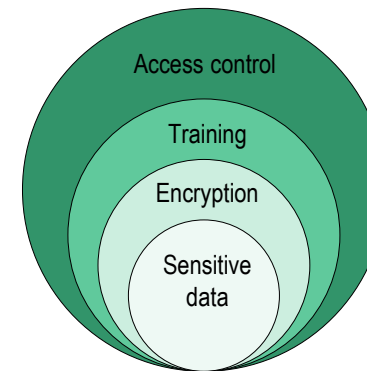
→ Avoid any access to the ECU via diagnostic interface and privileged accounts

- Production tools and equipment
 - List all equipment
 - E.g. PCs, PLCs, scanners, printers etc.
 - Identify needed tools
 - E.g. test tools, flashing software etc.
 - Identify versions

→ Inventory of used tools and equipment is needed for (secure) production

- Verification of post-development cybersecurity requirements
 - Define checks to verify that post-development cybersecurity requirements are met, either
 - Check manually that hardware plug protects debug interface
 - Automatic with pre-defined test cases :
 - To check removal of privileged accounts
 - To verify that correct firmware is flashed

- Cybersecurity controls
 - Defense-in-Depth approach to protect sensitive data
 - If one layer is bypassed, other layers protect the asset



[Clause 13]

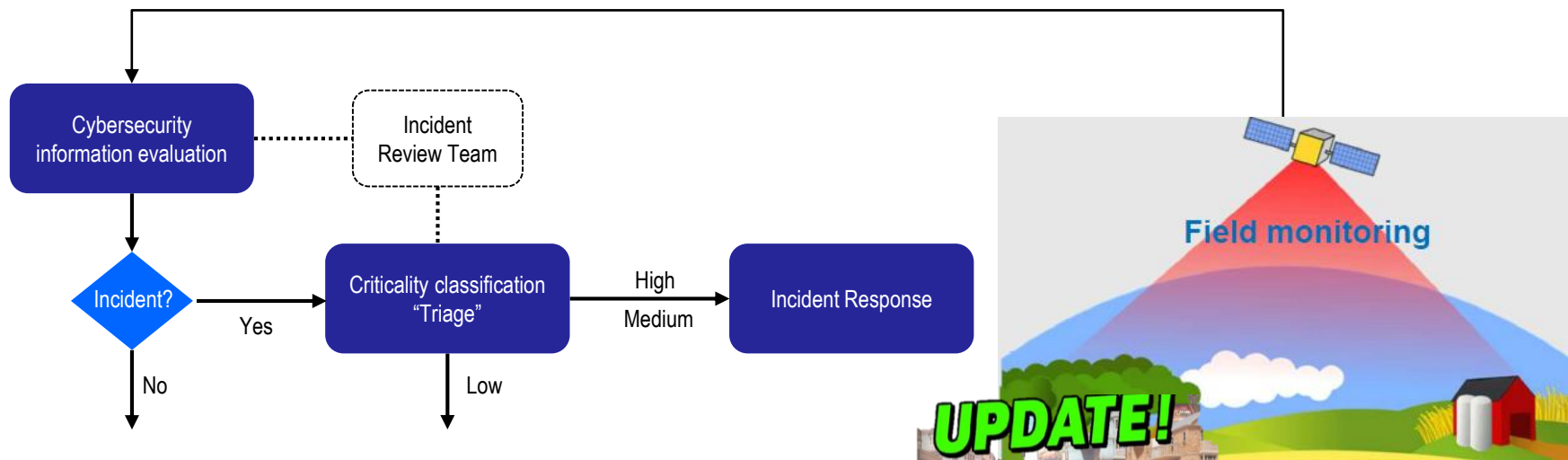
Operations and maintenance

[Clause 13] Operations and maintenance

LGE Internal Use Only

Objectives

- Determine and implement remedial actions for cybersecurity incidents
- Maintain cybersecurity during and after updates to items or components after production until their end of cybersecurity support



Terms

Cybersecurity information :

Information with regard to cybersecurity for which relevance is not yet determined

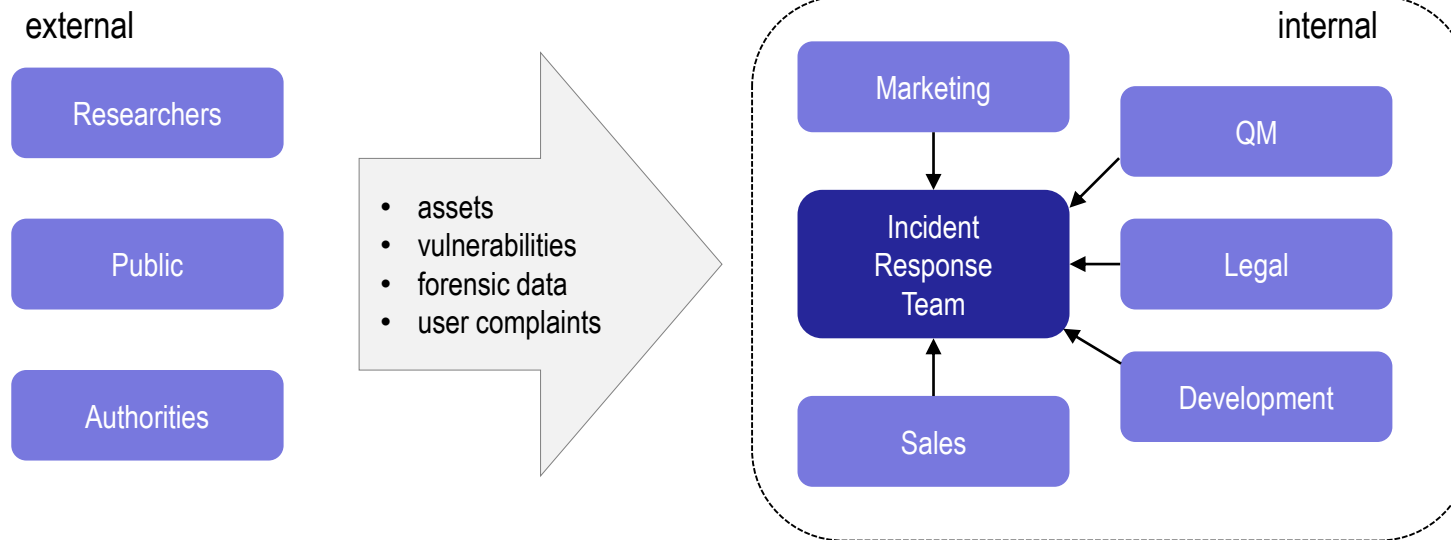
Cybersecurity incident :

Situation in the field that can involve vulnerability exploit mitigation

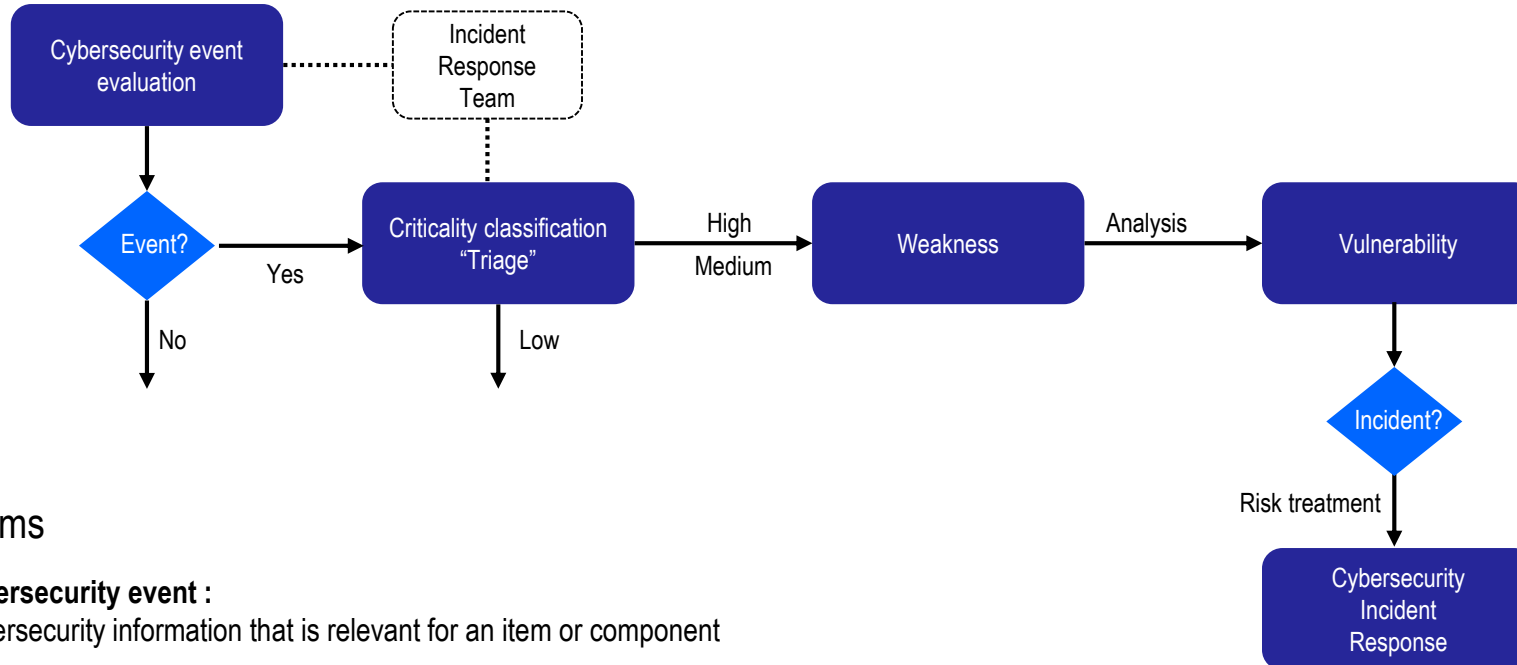
Triage :

Analysis to determine the relevance of cybersecurity information to an item or component

- Continuously monitoring shall be performed to identify cybersecurity issues as early as possible



Incident Response Process



Terms

Cybersecurity event :

Cybersecurity information that is relevant for an item or component

Weakness :

Defect or characteristic that can lead to undesirable behavior

Vulnerability :

Weakness that can be exploited as part of an attack path

Cybersecurity information :

Information with regard to cybersecurity for which relevance is not yet determined

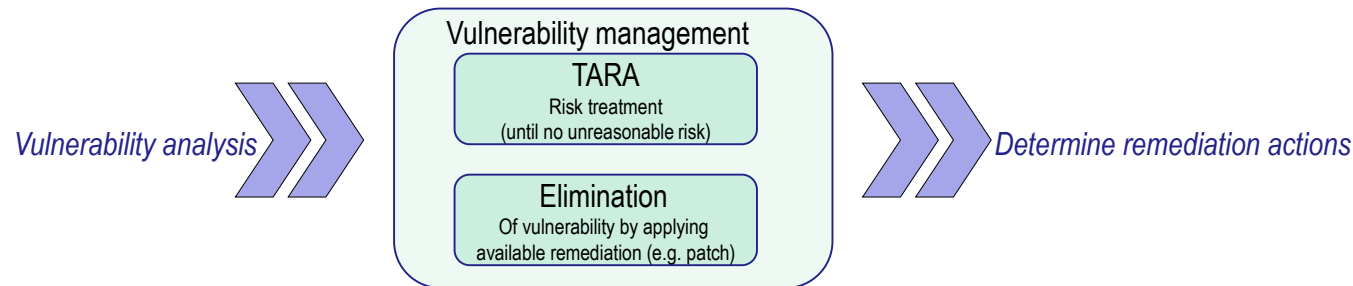
Cybersecurity incident :

Situation in the field that can involve vulnerability exploit mitigation

Triage :

Analysis to determine the relevance of cybersecurity information to an item or component

- Cybersecurity incident response plan shall be created that includes :
 - Remedial actions
 - Remedial actions are determined by vulnerability management



Vulnerability management tracks and oversees the treatment of identified vulnerabilities in items and components until their end of cybersecurity support

- Communication plan
- Assigned responsibilities for the remedial actions
- Procedure for recording new cybersecurity information relevant to the cybersecurity incident
- Method for determining progress
- Criteria for closure of the cybersecurity incident response
- Actions for the closure

- Update planning
 - Update capabilities?
 - Criticality categories?
 - How & Where to deliver?
 - Communicate end-of-support?

- Recovery information (What if an update fails?)
 - Testing of the update?
 - Rollback options?
 - Replace or repair?
 - Was it successful?

UNECE R156 / ISO 24089

[Clause 14]

End of cybersecurity support and decommissioning

[Clause 14] End of cybersecurity support and decommissioning

LGE Internal Use Only

- Objectives
 - Communicate the end of cybersecurity support
 - Enable decommissioning of items and components with regard to cybersecurity
- Procedure shall be created to communicate to customers when an organization decides to end cybersecurity support for an item or component
 - These communications can be handled under contract requirements between suppliers and customers
 - Communication to vehicle owners can be delivered by an announcement
- Cybersecurity requirements for post-development with regard to decommissioning shall be available
 - Appropriate documentation (e.g. instructions, user manuals) relating to such requirements can enable decommissioning with regard to cybersecurity

End of support

- OEM production/ maintenance is stopped
- Item/component can still function
- No more updates
- Supplier ends support of component



Under contract requirements between suppliers and customers
→ Communication to vehicle owners by announcement

Decommissioning

- Decommissioning occurs without organization's knowledge



Decommissioning is out of control of OEM,
but should be considered through the product's lifecycle

- End of cybersecurity support and decommissioning shall be considered from the beginning of product development

Concept phase

Consideration :

- Where are sensitive data stored?
- Is it possible to delete the memory?
- How can item be reset?
- How can we inform the car user how to delete data?
- What communication channel shall be established?
- ...

Sec_Req_21:

All sensitive data including credit card numbers, GPS data, address book information and audio files shall be stored in the Memory Unit

Sec_Req_25:

Memory Unit shall have the capability to be reset

Risk analysis

If Risk assessment identifies that data cannot be fully deleted and the remaining risk is not acceptable, all sensitive data might be encrypted

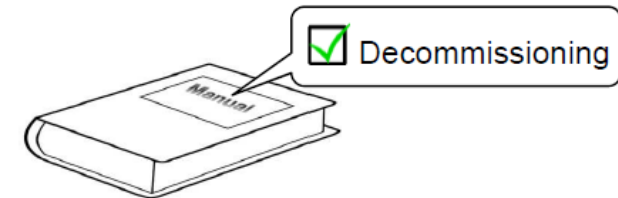
Product development phase

Sec_Req_25_01:

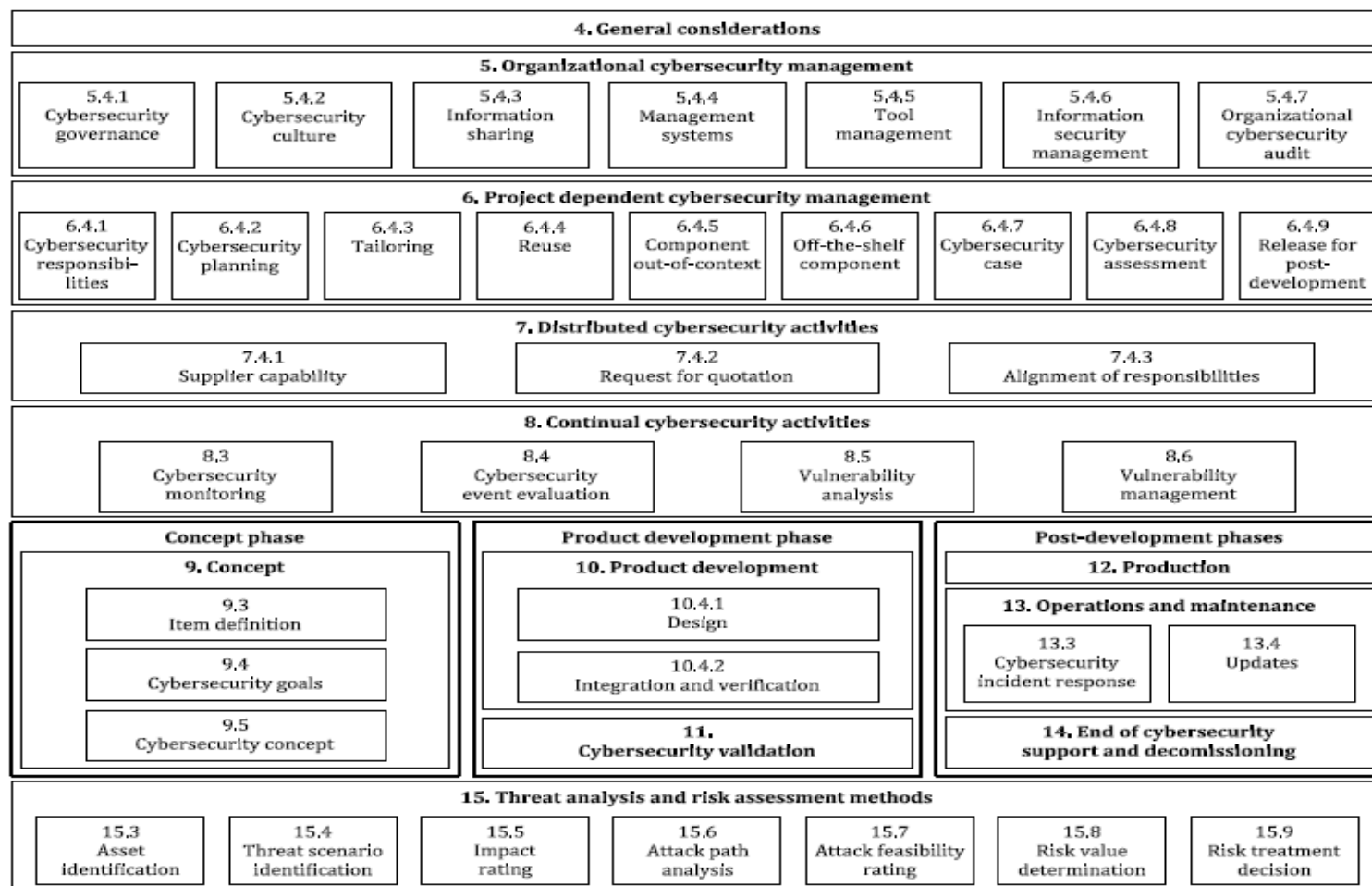
Memory Unit shall be resettable by pushing the Power Button and the Volume up Button for 5 sec

Sec_Req_25_02:

Description how to reset Memory Unit shall be described in the User Manual



Adequate description in User Manual how to reset the product is sufficient



ISO 21434 Analysis :

<http://collab.lge.com/main/x/-a2bW>